Manuale utente di Pseudomania

Personal edition e Enterprise edition – bozza 0.1

31 ottobre 2026

Indice

0. Avvertenze e disclaimer di responsabilità
- 0.1 Che cosa è Pseudomania, e che cosa non è
- 0.2 La responsabilità resta di chi adotta e usa il sistema
- 0.3 Nessuna garanzia
- 0.4 Componenti di terzi e servizi esterni
- 0.5 In sintesi

1. Cos’è e come funziona
- 1.1 In una frase
- 1.2 Lo schema
- 1.3 Le due edizioni
- 1.4 Che cosa viene riconosciuto
- 1.5 Che cosa viene protetto e che cosa no

2. Personal edition
- 2.1 Requisiti
- 2.2 Installare l’app desktop di Rizzo-PII
- 2.3 Installare l’estensione
- 2.4 Configurazione
- 2.5 Verifica: l’indicatore di stato
- 2.6 Attivare e disattivare la protezione (per conversazione)
- 2.7 File: PDF, DOCX, XLSX
- 2.8 Dati locali cifrati
- 2.9 Aggiornare
- 2.10 Disinstallare

3. Enterprise edition
- 3.1 Architettura in breve
- 3.2 Prerequisiti organizzativi
- 3.3 Ruoli
- 3.4 Installazione in sintesi
- 3.5 Chiave di custodia e custodi
- 3.6 Configurazione di Claude Team
- 3.7 Policy di Chrome
- 3.8 SSO e accesso condizionato
- 3.9 Proxy
- 3.10 MDM e blocco delle app
- 3.11 Durate di conservazione

4. Uso quotidiano
- 4.1 Prima di iniziare: controlla lo stato
- 4.2 Scrivere e inviare un messaggio
- 4.3 Allegati
- 4.4 Progetti
- 4.5 La risposta con i dati ripristinati
- 4.6 Anteprima prima dell’invio (Ctrl+Maiusc+Invio)
- 4.7 Il pannello di ispezione

4.8 Segnalazioni
4.9 Blocchi per categorie particolari di dati
4.10 Cambio PC: segnaposto non ripristinabili e recupero
4.11 Conferma annuale dei progetti (Enterprise)
4.12 Che cosa non fare
4.13 Domande frequenti

5. Creare una policy
5.1 Prima di scrivere: tre domande
5.2 Modello «light» (professionista o piccola organizzazione)
5.3 Modello «strutturato» (ente pubblico)
5.4 Tabella delle durate con le fonti (Enterprise edition)

6. Risoluzione dei problemi
6.1 Per tutti gli utenti
6.2 Personal edition
6.3 Enterprise edition (utente e help desk)

7. Glossario

Appendice – Riferimenti e link
A.1 Pseudomania
A.2 Componenti di terzi
A.3 Anthropic (Claude)
A.4 Norme e atti
A.5 Garante, EDPB, ACN, NIST

Avvertenze finali

0. Avvertenze e disclaimer di responsabilità

> **Leggere prima di installare o usare Pseudomania.** Queste avvertenze valgono per entrambe le edizioni (Personal edition ed Enterprise edition) e sono richiamate alla fine del manuale.

0.1 Che cosa è Pseudomania, e che cosa non è

Pseudomania è uno **strumento di mitigazione del rischio**. Sostituisce automaticamente i dati personali che riconosce con segnaposto (per esempio `[FULLNAME_1]`) prima che il testo arrivi a claude.ai, e rimette i dati reali nelle risposte, solo nel tuo browser.

Pseudomania **non è**:

- una **garanzia di anonimizzazione**: i dati pseudonimizzati **restano dati personali** ai sensi dell'art. 4, n. 5, del GDPR per chi detiene la corrispondenza tra segnaposto e valori reali (cioè per te o per la tua organizzazione);
- un sistema infallibile: il **rilevamento può non riconoscere** alcuni dati (nomi insoliti, refusi, sigle, dati scritti in forma non standard, dati dentro immagini) e **non riconosce il contesto** che rende identificabile una persona anche senza il nome (un ruolo unico, una data e un luogo precisi, un fatto noto, un numero di pratica);
- un filtro completo delle categorie particolari di dati (artt. 9 e 10 GDPR): il blocco si basa su un elenco di parole, che produce sia falsi positivi sia falsi negativi;
- una protezione per ciò che non passa dall'estensione: **preferenze del profilo Claude**, **richieste di ricerca web** formulate da Claude, **connettori**, **app desktop e mobile** di Claude, altri browser e dispositivi.

0.2 La responsabilità resta di chi adotta e usa il sistema

Tutta la responsabilità giuridica connessa all'adozione e all'uso di Pseudomania e del servizio di intelligenza artificiale resta **interamente** in capo a chi adotta e usa il sistema (il singolo professionista, l'impresa o l'ente, e i loro utenti). In particolare, a titolo di esempio e non esaustivo, resta a carico di chi adotta e usa il sistema:

- il rispetto del **GDPR** (Reg. UE 2016/679) e del **Codice privacy** (d.lgs. 196/2003): base giuridica, informative, registro dei trattamenti, misure di sicurezza, gestione delle violazioni, diritti degli interessati;
- la valutazione della necessità e la redazione della **DPIA** (art. 35 GDPR) e l'eventuale consultazione preventiva del Garante (art. 36);
- l'adozione di **policy e regolamenti** d'uso, la formazione del personale e l'alfabetizzazione in materia di IA (art. 4 del Reg. UE 2024/1689, AI Act);
- il rispetto del **diritto del lavoro**, in particolare dell'art. 4 della L. 300/1970 (Statuto dei lavoratori) e degli artt. 113-114 del Codice privacy, con l'eventuale accordo sindacale o autorizzazione dell'Ispettorato nazionale del lavoro;

- i **contratti con i fornitori di IA** (condizioni d'uso, accordo sul trattamento dei dati, trasferimenti verso Paesi terzi, sub-responsabili) e la verifica che l'uso dell'estensione sia compatibile con tali condizioni;
- gli **esiti dell'uso dell'IA**: correttezza, completezza e liceità dei testi prodotti e delle decisioni prese anche sulla base di essi, segreti professionali e d'ufficio, diritti di terzi.

I modelli di policy, informativa, DPIA e checklist citati in questo manuale (cartella `governance/` del repository) sono **bozze da adattare**, non consulenza legale. Le indicazioni normative marcate **[DA VERIFICARE]** non sono state controllate sul testo ufficiale.

0.3 Nessuna garanzia

Pseudomania è software libero distribuito con licenza **GNU Affero General Public License, versione 3 o successiva (AGPL-3.0-or-later)**. Come previsto dalle **sezioni 15 (Disclaimer of Warranty) e 16 (Limitation of Liability)** della licenza:

- il programma è fornito **«così com'è» (*as is*), senza garanzia di alcun tipo**, espressa o implicita, incluse le garanzie di commerciabilità e di idoneità a uno scopo particolare, nei limiti consentiti dalla legge applicabile; **l'intero rischio** quanto alla qualità e al funzionamento del programma è a carico di chi lo usa;
- **in nessun caso**, salvo quanto imposto dalla legge applicabile o concordato per iscritto, i titolari del copyright o chiunque modifichi e/o distribuisca il programma **sono responsabili** per danni generali, speciali, incidentali o consequenziali derivanti dall'uso o dall'impossibilità di usare il programma, inclusi la perdita di dati, dati resi inesatti o perdite subite da chi lo usa o da terzi.

Il testo vincolante è quello inglese della licenza (file `LICENSE` nel repository); la sezione 17 della licenza regola l'interpretazione delle sezioni 15 e 16 dove queste non possano avere effetto secondo la legge locale.

0.4 Componenti di terzi e servizi esterni

Pseudomania usa componenti di terzi con licenze proprie (tra cui Privacy Guardrail del DFKI, Apache-2.0, e Rizzo-PII, vedi `THIRD_PARTY_NOTICES.md`). Gli autori di Pseudomania **non hanno alcun rapporto** con Anthropic (fornitore di Claude) né con gli autori di Rizzo-PII e non rispondono del loro funzionamento, delle loro condizioni o delle loro modifiche. claude.ai può cambiare in qualunque momento e rendere l'estensione temporaneamente inefficace.

0.5 In sintesi

> Pseudomania **riduce** il rischio di inviare dati personali a un servizio di IA; **non lo elimina**. Controlla sempre che cosa stai inviando, non inserire dati che non devono uscire, verifica le risposte. Chi adotta e usa il sistema ne resta l'unico responsabile; gli autori non rispondono di alcun danno.

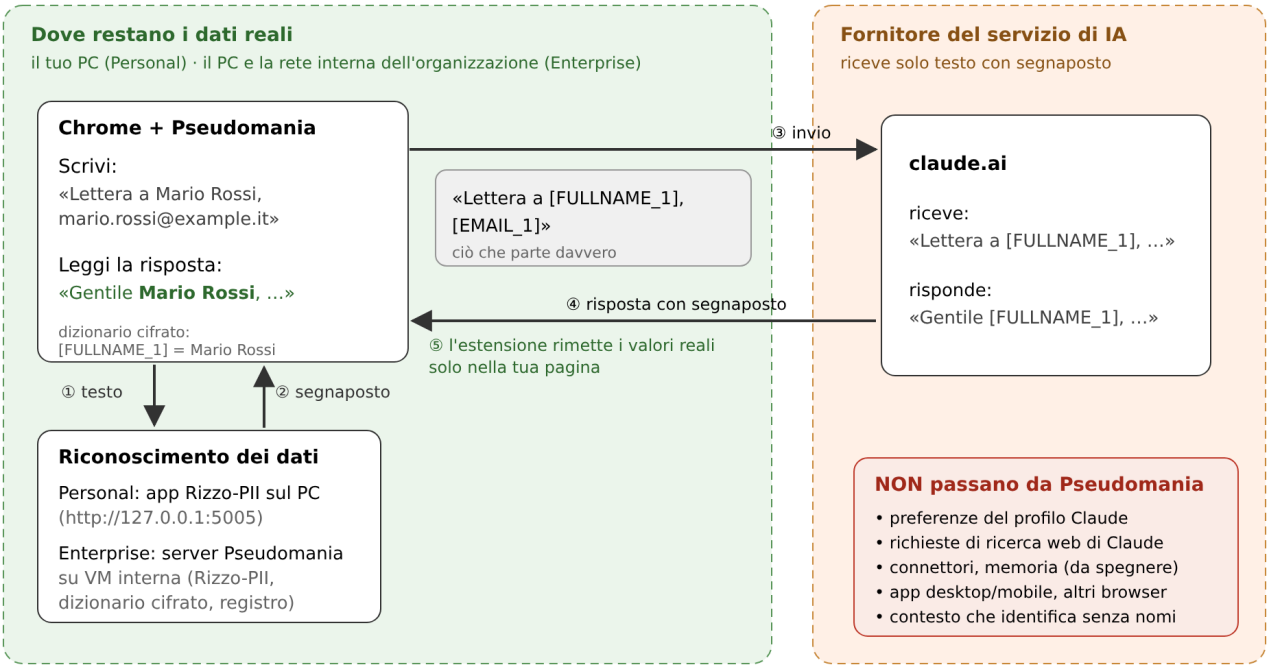
1. Cos’è e come funziona

1.1 In una frase

Pseudomania è un’estensione per Google Chrome che, quando usi **claude.ai**, sostituisce automaticamente i dati personali che riconosce con **segnaposto** prima dell’invio e rimette i **dati reali** nelle risposte di Claude, solo sullo schermo del tuo computer.

Sito ufficiale: https://pseudomania.statocritico.it · Licenza: AGPL-3.0-or-later.

1.2 Lo schema



Schema di funzionamento di Pseudomania

1. **Scrivi** in claude.ai come al solito (testo, allegati, istruzioni e file dei progetti).
2. Al momento dell’invio l’estensione passa il testo al **servizio di riconoscimento**: l’app desktop **Rizzo-PII** sul tuo PC (Personal edition) oppure il **server Pseudomania** dell’organizzazione sulla rete interna (Enterprise edition).
3. I dati riconosciuti diventano **segnaposto** nella forma `[TIPO_N]`, per esempio `[FULLNAME_1]` (nome e cognome), `[EMAIL_1]`, `[CF_1]` (codice fiscale), `[IBAN_1]`. Lo stesso valore, nella stessa conversazione o nello stesso progetto, riceve sempre lo stesso segnaposto.
4. A claude.ai parte **solo il testo con i segnaposto**, preceduto (nel primo messaggio di ogni conversazione) da un’istruzione fissa che chiede a Claude di riportare i segnaposto senza modificarli.
5. Quando arriva la risposta, l’estensione sostituisce i segnaposto con i valori reali **nella pagina** (evidenziati in verde). La corrispondenza segnaposto → valore (il **dizionario**) è cifrata e non lascia mai il tuo controllo in chiaro.

1.3 Le due edizioni

	Personal edition	**Enterprise edition**
Per chi	singolo professionista, piccola organizzazione	enti pubblici e imprese
Componenti	estensione + app desktop **Rizzo-PII** sul PC	estensione imposta da policy di Chrome + **server** su VM interna + Langfuse (facoltativo)
Riconoscimento	sul PC (`http://127.0.0.1:5005`)	sul server dell'organizzazione
Dizionario	nel browser, cifrato con chiave locale	sul server, **cifrato nel browser** con chiave utente automatica; copia di custodia apribile solo da due custodi
Registro	locale, cifrato, senza testi	registro minimo sul server senza testi + tracce pseudonimizzate brevi (Langfuse)
Si può spegnere?	sì, per singola conversazione, con un clic o Alt+Maiusc+P (il ripristino resta sempre attivo)	no: pulsante bloccato su acceso dalla policy
Se il riconoscimento non risponde	avviso e richiesta di conferma	invio **bloccato** (*fail-closed*)
Server Pseudomania, Docker	**nessuno**	sì

1.4 Che cosa viene riconosciuto

Il riconoscimento è affidato a **Rizzo-PII**, un modello open source specializzato in dati personali in italiano. I tipi di segnaposto previsti sono: `FULLNAME`, `EMAIL`, `TELEPHONENUM`, `STREET`, `BUILDINGNUM`, `ZIPCODE`, `CITY`, `PROVINCE`, `IBAN`, `CREDITCARDNUMBER`, `AMOUNT`, `CF`, `PIVA`, `CATASTO`, `DOCID`, `ID_DOC`, `ORG`, `DATE`, `TIME`, `TARGA`, `AGE`, `GENDER`, `URL`, `IPADDR`.

Alcuni termini pubblici (enti, istituzioni) sono in un **elenco di eccezioni** (*allowlist*) e non vengono mai mascherati.

Inoltre un **filtro delle categorie particolari** (salute, disabilità, dati genetici o biometrici, origine etnica, opinioni politiche, convinzioni religiose, appartenenza sindacale, vita sessuale, condanne penali e reati: artt. 9 e 10 GDPR) **blocca l'invio** quando trova certe parole: questi dati non devono essere inviati nemmeno pseudonimizzati, perché il contesto resta un dato particolare («[FULLNAME_1] è in malattia per depressione»). Le regole sono una **bozza** da validare con il DPO.

1.5 Che cosa viene protetto e che cosa no

Protetto (passa dall'estensione)	**Non protetto**
messaggi, modifiche e reinvii	**preferenze personali del profilo Claude**

Protetto (passa dall’estensione)	Non protetto
allegati DOCX, XLSX, TXT, CSV, MD; PDF (vedi §2.7 e §4.3)	**richieste di ricerca web** che Claude formula da sé
istruzioni e file dei **progetti**	**connettori** (Google Drive, Gmail…) e **memoria** di Claude: vanno spenti
testo lungo incollato che claude.ai trasforma in allegato	**app desktop e mobile** di Claude, altri browser, modalità in incognito
download di file DOCX/XLSX/testo generati da Claude (ripristino)	**immagini** (vengono bloccate, non analizzate)
copia del testo delle risposte (appunti con i valori reali)	il **contesto** che identifica una persona anche senza nome

Limiti tecnici importanti (dettagli in `extension/README.md` §7):

- i valori ripristinati sono **nel codice della pagina** di claude.ai, quindi gli script del sito potrebbero leggerli;
- gli **artifact** mostrati in riquadri di un altro dominio non vengono ripristinati;
- la **dettatura vocale** è disattivata dall’estensione;
- i **selettori** con cui l’estensione riconosce la pagina di claude.ai non sono ancora stati verificati sul sito reale **[DA VERIFICARE]**: se claude.ai cambia, l’estensione lo segnala («Pagina non riconosciuta da Pseudomania»).

2. Personal edition

Per il **singolo professionista** (avvocato, commercialista, consulente del lavoro, ingegnere, ecc.) o la piccola organizzazione che usa claude.ai e vuole ridurre il rischio di inviare i dati personali dei propri clienti.

La Personal edition è fatta di **due soli componenti sul tuo PC**: l'app desktop **Rizzo-PII** (riconosce i dati) e l'**estensione Pseudomania** per Chrome (sostituisce e ripristina). Nessun server, nessun Docker, nessun account aggiuntivo.

> **È uno strumento volontario.** Puoi spegnerlo con un clic, conversazione per conversazione, e non protegge altri browser né le app di Claude. Sei tu il titolare (o il responsabile, per conto del cliente) dei trattamenti: rileggi le avvertenze del capitolo 0 e, prima di iniziare, prepara le tue regole d'uso con il modello «light» del capitolo 5.

2.1 Requisiti

Requisito	Note
PC con Windows, macOS o Linux	secondo i pacchetti offerti da Rizzo-PII; il rilascio 1.0.0 riporta un installer Windows, un AppImage Linux x86_64 e un'immagine macOS per Apple Silicon (arm64) **[DA VERIFICARE per il rilascio più recente]**
Memoria (RAM)	almeno 8 GB consigliati: il modello di Rizzo-PII gira sul processore (stima)
Google Chrome desktop, versione 116 o successiva	serve il pannello laterale; non funziona su Chrome per telefono
Connessione a Internet	per scaricare l'app e, al primo avvio, il modello; poi il riconoscimento avviene sul PC
Account claude.ai	Free, Pro, Max o Team; per i piani consumer vedi §2.6
Profilo Chrome personale e PC protetto	cifratura del disco, blocco dello schermo: chi usa il tuo profilo vede i valori ripristinati

2.2 Installare l'app desktop di Rizzo-PII

Istruzioni tecniche di dettaglio: `docs/installazione-personale.md`.

Rizzo-PII è un progetto open source **separato** da Pseudomania (codice MIT; i pacchetti desktop includono componenti AGPL-3.0).

1. Apri la pagina dei rilasci: https://github.com/Rizzo-AI-Academy/rizzo-pii/releases.

2. Scarica il pacchetto per il tuo sistema (per esempio, nel rilascio 1.0.0: `Rizzo-PII-1.0.0-Windows-Setup.exe`, `Rizzo-PII-1.0.0-Linux-x86_64.AppImage`, `Rizzo-PII-1.0.0-macOS-arm64.dmg`) e installalo come un normale programma **[DA VERIFICARE: nomi dei file e procedura del rilascio più recente, 2.0.0]**. Istruzioni del progetto: https://github.com/Rizzo-AI-Academy/rizzo-pii/wiki.
3. **Avvia l'app.** Al primo avvio scarica e carica il modello (circa 1–2 GB): può richiedere alcuni minuti. Finché il modello non è pronto il servizio risponde «non pronto».
4. **Controlla che il servizio locale risponda**: apri in Chrome l'indirizzo `http://127.0.0.1:5005/health`. Deve rispondere senza errori. Se compare una schermata per scegliere indirizzo e porta (la porta 5005 è occupata), annota la porta scelta: andrà indicata nelle impostazioni dell'estensione (§2.4).
5. **Firewall** (Windows): se il sistema chiede di consentire all'app l'accesso alla rete, nega o consenti solo le reti private. Il servizio deve restare **solo** sul tuo PC (`127.0.0.1`).
6. Se l'app lo prevede, impostala in **avvio automatico**, così è pronta quando apri Chrome.

> **Se l'estensione non riesce a dialogare con Rizzo-PII.** Il servizio locale di Rizzo-PII non è stato progettato per ricevere chiamate da un'estensione del browser. Nelle prove (con un Rizzo-PII simulato) Chrome le accetta comunque; **con l'app desktop reale non è ancora stato provato [DA VERIFICARE]**. Se l'estensione mostra il messaggio «Rizzo-PII risponde ma rifiuta le chiamate dell'estensione (CORS)», **verrà fornita una versione modificata di Rizzo-PII** adatta a Pseudomania, scaricabile dal sito https://pseudomania.statocritico.it. Fino ad allora **non usare la Personal edition con dati di clienti**.

2.3 Installare l'estensione

Dal Chrome Web Store (quando sarà disponibile **[DA VERIFICARE]**): apri il collegamento indicato sul sito https://pseudomania.statocritico.it e scegli **Aggiungi a Chrome**.

Dal pacchetto del codice, finché non è sul Web Store:

1. Scarica il codice di Pseudomania (collegamento sul sito) e scompattalo in una cartella che non sposterai più, per esempio `C:\pseudomania` oppure `~/pseudomania`.
2. In Chrome apri l'indirizzo `chrome://extensions`.
3. Attiva **Modalità sviluppatore** (interruttore in alto a destra).
4. Scegli **Carica estensione non pacchettizzata** e seleziona la cartella `extension` (quella che contiene il file `manifest.json`).
5. Fissa l'icona nella barra: icona a forma di **puzzle** → puntina accanto a **Pseudomania**.

Senza alcuna policy aziendale l'estensione parte automaticamente in **Personal edition** (la pagina «Impostazioni e informazioni» lo indica: «Personal edition»).

2.4 Configurazione

1. **Clic destro** sul pulsante di Pseudomania → **Impostazioni e informazioni** (pagina «Impostazioni di Pseudomania»).

2. Campo **Indirizzo di Rizzo-PII desktop**: lascia `http://127.0.0.1:5005` (predefinito) oppure la porta scelta al §2.2. Sono ammessi **solo indirizzi locali** (`127.0.0.1` o `localhost`).

3. Clic su **Verifica connessione**. Esiti possibili:

Messaggio	Cosa fare
«Rizzo-PII raggiungibile.»	tutto a posto: **Salva**
«Rizzo-PII si sta avviando: riprova tra poco.»	attendi il caricamento del modello e riprova
«Rizzo-PII non raggiungibile: avvia l'app desktop.»	avvia Rizzo-PII; controlla porta e indirizzo
«Rizzo-PII risponde ma rifiuta le chiamate dell'estensione (CORS)…»	vedi il riquadro del §2.2

4. Clic su **Salva** («Impostazioni salvate.»).

Non ci sono altre impostazioni obbligatorie. In fondo alla pagina, nella sezione «Informazioni», trovi versione, licenza e sito.

2.5 Verifica: l'indicatore di stato

Lo stato è **sempre visibile** in due punti e si riferisce sempre alla **conversazione aperta** nella scheda.

Badge sul pulsante dell'estensione

Badge	Significato
ON verde	protezione attiva in questa conversazione
OFF rosso (icona grigia)	protezione **disattivata** in questa conversazione: ciò che invii parte in chiaro
? arancione	in attesa della tua scelta (§2.6); nel frattempo i messaggi vengono pseudonimizzati
! rosso	Rizzo-PII spento, in avvio o non raggiungibile (CORS)

Barra colorata sopra la casella di scrittura di claude.ai: verde «Pseudomania attivo: i dati personali vengono pseudonimizzati prima dell'invio»; rossa «Protezione disattivata per questa conversazione: …»; arancione mentre attende la tua scelta.

Prova rapida (con dati inventati):

1. Apri claude.ai, nuova chat.
2. Scrivi: `Scrivi una breve lettera a Mario Rossi, mario.rossi@example.it` e invia.
3. Nel fumetto del messaggio inviato devono comparire `[FULLNAME_1]` e `[EMAIL_1]` (e, nel primo messaggio, l'istruzione fissa sui segnaposto).

4. Nella risposta di Claude «Mario Rossi» e l’indirizzo email devono tornare visibili, **evidenziati in verde**.
5. Sotto il messaggio inviato compare il contrassegno «2 dati protetti»: cliccandolo si apre il pannello di ispezione (§4.7).

Se la prova non riesce, vedi il capitolo 6.

2.6 Attivare e disattivare la protezione (per conversazione)

Nella Personal edition la protezione si sceglie **conversazione per conversazione**.

Il pulsante di Pseudomania nella barra degli strumenti di Chrome (non apre una finestra):

Azione	Effetto
clic sul pulsante, con claude.ai aperto	attiva o disattiva la protezione della **conversazione aperta** nella scheda; compare per un attimo «Pseudomania attivato per questa conversazione» oppure «Pseudomania disattivato per questa conversazione: i messaggi partiranno in chiaro»
scorciatoia **Alt+Maiusc+P**	come il clic (modificabile da `chrome://extensions/shortcuts`)
clic destro sul pulsante	menu con «Apri pannello di ispezione» e «Impostazioni e informazioni»
clic su una scheda che non è claude.ai	apre le impostazioni

Lo stato si salva per conversazione (dentro un progetto, per ogni chat). Quando cambi chat nella stessa scheda, badge e barra si aggiornano subito.

Nuova conversazione o conversazione ripresa

Situazione	Che cosa succede
nuova conversazione, l’ultima scelta era «attiva»	si attiva da sola
nuova conversazione, l’ultima scelta era «disattivata»	compare il banner «Protezione disattivata l’ultima volta – Vuoi attivare Pseudomania per questa conversazione?» con **Attiva** / **Continua senza protezione**
conversazione ripresa che era attiva	si riattiva da sola
conversazione ripresa che era disattivata	stesso banner

Finché non scegli, **per prudenza i messaggi vengono comunque pseudonimizzati**: badge **?** arancione e barra arancione «Scegli se proteggere questa conversazione: nel frattempo i messaggi vengono pseudonimizzati».

Che cosa cambia spegnendo. La disattivazione riguarda **solo ciò che invii**: messaggi e allegati partono in chiaro, così come li scrivi (barra rossa «Protezione disattivata per questa conversazione: i messaggi partono in chiaro (i segnaposto ricevuti vengono comunque ripristinati)»). Il **ripristino** dei segnaposto nelle risposte, negli appunti e nei download resta **sempre attivo**.

Primo spegnimento in una conversazione che contiene già dati protetti: compare l'avviso «Disattivare la protezione in questa conversazione?» — da ora ciò che invii andrà a Claude in chiaro e **riattivare in seguito non ripulisce quanto già inviato**. Conferma con **Disattiva** o rinuncia.

Ogni cambio di stato viene annotato nel registro locale (solo l'evento, nessun testo).

Quando Rizzo-PII non risponde l'estensione **non invia di nascosto**: mostra la finestra «Rizzo-PII non risponde» con l'esito di un **controllo locale di base** (email, codici fiscali, IBAN, telefoni, partite IVA) e due pulsanti: **Annulla** e **Invia senza protezione**. Il controllo di base **non maschera nulla** e non è una garanzia: se il messaggio contiene dati di clienti, scegli **Annulla** e riavvia Rizzo-PII.

Impostazioni di Claude consigliate (piani Free, Pro, Max)

I piani consumer seguono condizioni diverse da quelle commerciali (Team, Enterprise): in particolare le conversazioni possono essere usate per migliorare i modelli se l'impostazione è attiva. Consigli:

1. claude.ai → profilo → **Impostazioni** → **Privacy**: disattiva l'uso delle chat per migliorare i modelli **[DA VERIFICARE: etichetta esatta]**.
2. Disattiva la **memoria** di Claude: riporterebbe segnaposto tra conversazioni diverse, che non possono essere ripristinati.
3. Disattiva i **connettori** che non servono (i loro contenuti non passano da Pseudomania).
4. Non usare i pulsanti di **feedback** (pollice su/giù) nelle chat con dati di clienti.
5. Non scrivere dati personali nelle **preferenze del profilo** né chiedere ricerche web su persone.
6. Per un uso professionale stabile con dati di clienti valuta un **piano commerciale**.

2.7 File: PDF, DOCX, XLSX

Formato	Che cosa succede
DOCX, XLSX	pseudonimizzati **dentro l'estensione** (testo, intestazioni e piè di pagina, note, commenti, proprietà del documento, celle e valori delle formule). A Claude arriva il file con i segnaposto. Quando scarichi un DOCX o XLSX generato da Claude, i valori reali vengono ripristinati.
TXT, CSV, MD	pseudonimizzati

Formato	Che cosa succede
PDF	il testo viene estratto da Rizzo-PII e inviato a Claude come **file di testo pseudonimizzato (.txt)** al posto del PDF. Compare l'avviso: «Il PDF … è stato convertito in un file di testo pseudonimizzato (.txt): impaginazione, immagini e tabelle grafiche non vengono inviate a Claude.» Il PDF non viene ripristinato al download.
Immagini e altri formati	**bloccati**: il file non viene allegato

Consiglio: per documenti lunghi apri l'**anteprima** (Ctrl+Maiusc+Invio, §4.6) o il pannello di ispezione e controlla che cosa parte davvero.

2.8 Dati locali cifrati

Tutto resta nel tuo profilo Chrome, nell'archivio dell'estensione (IndexedDB, database `pseudomania`). **Nessun dato va a server di Pseudomania**; a claude.ai arriva solo il testo con i segnaposto.

Dato	Protezione	Durata
Dizionario delle **chat**	valori cifrati (AES-GCM) con una chiave locale **non estraibile**; indice valore → segnaposto con HMAC a chiave locale	30 giorni dall'ultimo uso
Dizionario delle **chat nuove non ancora salvate** da claude.ai	come sopra	24 ore
Dizionario dei **progetti**	come sopra	finché non lo elimini tu dal pannello
Registro locale	cifrato; solo azioni, conteggi e impronte, **mai testi**	90 giorni (valore predefinito del prodotto)
Dati del pannello di ispezione (originale e inviato)	solo in memoria della sessione	fino alla chiusura del browser

Conseguenze da conoscere:

- **Nessun backup**: la chiave non si può esportare, per scelta. Il dizionario non si trasferisce su un altro PC o un altro profilo Chrome.
- **Cambio PC, nuovo profilo, cancellazione dei dati del browser** (con i dati dei siti e delle estensioni): i dizionari sono persi e nelle vecchie conversazioni i segnaposto restano tali. Nella Personal edition **non esiste recupero**. Conserva i dati reali che ti servono nei tuoi fascicoli, fuori da Claude.
- **Cancellare un dizionario**: pannello di ispezione → «Elimina i dati di questa conversazione» o «Elimina i dati di questo progetto». È definitivo («Dati eliminati da questo computer.»).
- Le conversazioni restano su claude.ai (con i segnaposto) secondo le condizioni di Anthropic, finché non le cancelli.

2.9 Aggiornare

- Estensione dal Web Store: si aggiorna da sola.
- Estensione dal pacchetto: sostituisci i file **nella stessa cartella**, poi `chrome://extensions` → **Aggiorna**. **Non rimuovere** l'estensione per aggiornarla: perderesti dizionario e registro.
- Rizzo-PII: segui le istruzioni del progetto per i nuovi rilasci.

2.10 Disinstallare

1. `chrome://extensions` → Pseudomania → **Rimuovi**. Vengono cancellati in modo irreversibile anche dizionario e registro locali.
2. Disinstalla l'app Rizzo-PII dal sistema operativo e, se vuoi liberare spazio, cancella la cache del modello **[DA VERIFICARE: posizione della cache dell'app desktop]**.
3. Cancella da claude.ai le conversazioni che non ti servono più.

3. Enterprise edition

Per **enti pubblici e imprese** che danno ai dipendenti account **Claude Team** e vogliono ridurre il rischio che dati personali arrivino al fornitore. L'Enterprise edition **non è solo software**: funziona solo insieme a impostazioni della console di Claude, policy di Chrome, accesso condizionato, regole d'uso, DPIA, accordo sindacale e custodi.

Questo capitolo è una **panoramica** per chi decide e per il responsabile IT. Le istruzioni tecniche complete e aggiornate sono nella cartella `docs/` del repository:

Documento	Per chi	Contenuto
`docs/installazione-ente.md`	amministratori di sistema	dalla VM al servizio in esercizio, backup, ripristino, conservazione
`docs/custodi.md`	custodi, DPO, amministratori	chiave di custodia, recupero, autorità giudiziaria, verbali
`docs/configurazione.md`	amministratori di Claude Team, identità, postazioni, rete	console Claude, identity provider, policy di Chrome, blocco app, proxy
`docs/verifica-pilota.md`	amministratori, sicurezza, DPO	prove da superare prima dell'avvio
`docs/PROBLEMI-RILEVATI.md`	sviluppo e IT	difetti noti e rimedi operativi

Ordine consigliato: installazione (con la generazione della chiave di custodia **prima** del primo avvio) → configurazione → verifica del pilota.

3.1 Architettura in breve

- **Estensione Chrome** installata in modo **forzato e non disattivabile** sui browser gestiti; la configurazione arriva dalla policy di Chrome (`mode: "ente"`).
- **Server Pseudomania** su una VM Linux interna (Docker Compose): API, **Rizzo-PII** senza accesso a Internet, database applicativo (dizionario cifrato, registro minimo), **key store separato** (copie di custodia delle chiavi), **OpenBao** (solo la chiave HMAC), **Caddy** (TLS, unica porta esposta: 443).
- **Langfuse** (facoltativo): tracce con i soli testi pseudonimizzati, in un progetto dedicato. Può girare sulla VM oppure essere un Langfuse **condiviso o esterno** già usato dall'organizzazione (§3.4, punto 7).
- **Identity provider** dell'organizzazione (OIDC) per autenticare l'estensione presso il server.
- **Fail-closed**: se il server non risponde, l'invio è **bloccato**.

Che cosa protegge la cifratura. Ogni utente ha una chiave generata automaticamente dal suo browser, non estraibile, con cui l'estensione cifra i valori del dizionario prima di inviarli al server. Una copia della chiave, cifrata con la **chiave pubblica di custodia**, è conservata nel key store; la chiave privata di custodia non è mai sul server ed è divisa tra i custodi (2 di 3). Le chiavi ruotano ogni 90 giorni. **Rischio residuo dichiarato**: il server vede

il testo in chiaro durante la singola richiesta; chi ha i privilegi di root sulla VM può intercettare richieste future, non decifrare i dizionari passati; può verificare se un valore indovinato è presente (HMAC).

3.2 Prerequisiti organizzativi

Prima di installare (dettagli e riferimenti nel capitolo 5 e in `governance/checklist-adempimenti.md`):

☐ decisione formale di adozione e perimetro del **pilota** (utenti, durata);
☐ abbonamento **Claude Team** con accordo commerciale e **DPA** di Anthropic verificati;
☐ **DPIA** con parere del DPO (bozza in `governance/dpia.md`);
☐ **accordo sindacale** o autorizzazione dell'Ispettorato nazionale del lavoro (art. 4, c. 1, L. 300/1970) che copra registro minimo, tracce, esportazione e procedura dei custodi;
☐ **regolamento d'uso** con informativa (Allegato A), procedura di cancellazione (Allegato B) e procedura dei custodi (Allegato C) (bozza in `governance/policy-uso-ia.md`);
☐ **designazioni**: amministratori di sistema, almeno **tre custodi** distinti dagli amministratori, persone autorizzate;
☐ **formazione** degli utenti e dei custodi;
☐ PC gestiti (dominio, Intune/MDM o Chrome Enterprise Core), Chrome come browser gestito;
☐ una VM Linux interna (pilota di 6 utenti, stima: 8 vCPU, 16–24 GB di RAM, 100 GB SSD), DNS interno, certificati TLS dell'organizzazione;
☐ un identity provider OIDC (Keycloak, Microsoft Entra ID o altro) e l'SSO per Claude Team.

3.3 Ruoli

Ruolo	Che cosa fa	Che cosa non fa
Titolare (legale rappresentante, dirigente delegato)	adotta regolamento e DPIA, designa i ruoli, stipula i contratti	—
DPO / RPD	parere sulla DPIA, sorveglianza, presente alle cerimonie dei custodi, punto di contatto per gli interessati	non amministra il sistema
Amministratori di sistema	VM, server, backup, Chrome Enterprise, SSO, proxy, Langfuse, console Claude Team con ruoli diversi dal Primary Owner; esportano per i custodi i file cifrati; caricano le chiavi recuperate	**nessun accesso** alla chiave privata di custodia né all'account Primary Owner; accedono al registro solo in forma aggregata o pseudonima
Custodi (almeno 3, ne servono 2)	tengono le quote della chiave privata di custodia e, divise tra due di loro, password e secondo fattore dell'account Primary Owner; operano offline, con verbale	non accedono ai contenuti per richieste diverse da autorità giudiziaria e recupero di progetti; non usano l'account Primary Owner per l'amministrazione ordinaria

Ruolo	Che cosa fa	Che cosa non fa
Help desk / assistenza	primo contatto per gli utenti: avvisi dell'estensione, accesso, richieste di recupero (ticket con il codice del dispositivo), segnalazioni	non chiede mai agli utenti di disattivare l'estensione o di inviare dati reali
Dirigente / referente del servizio	individua gli utenti, approva le richieste motivate di recupero dei progetti	non può chiedere i contenuti delle conversazioni
Utenti	usano claude.ai secondo il regolamento, segnalano anomalie, confermano i progetti ogni anno	non aggirano né manomettono l'estensione

3.4 Installazione in sintesi

Procedura completa: `docs/installazione-ente.md`. Comandi eseguiti nella cartella `/opt/pseudogate/deploy` della VM.

1. **VM e rete**: Ubuntu Server 24.04 LTS o Debian 12; nomi DNS interni (es. `pseudogate.ente.local`, `langfuse.ente.local`); certificati dell'ente; Docker Engine.
2. **Codice**: `git clone` del repository in `/opt/pseudogate` (URL indicato sul sito) e annotazione del commit.
3. **Immagini**: `docker compose build api rizzo-pii` (anche su un'altra macchina, per VM senza Internet).
4. **Chiave di custodia** (prima del primo avvio): i custodi la generano **offline** con `tools/custodi/custodi.py genera-chiave`; sulla VM si copiano **solo** i due file pubblici (`escrow_public.pem`, `escrow_key_id.txt`) in `deploy/custodia/` (§3.5).
5. **Segreti e `.env`**: `./scripts/genera-segreti.sh`, poi a mano dominio, `OIDC_ISSUER`, `OIDC_AUDIENCE`, `CORS_ALLOW_ORIGIN_REGEX`, `SOURCE_URL`, destinazioni e chiavi dei due backup. Per le CA interne (IdP, Langfuse condiviso) `EXTRA_CA_FILE`: le CA si aggiungono a quelle pubbliche per **tutte** le chiamate HTTPS dell'API (vale ancora il vecchio `OIDC_CA_FILE`); per un proxy in uscita `OUTBOUND_HTTPS_PROXY` (vale ancora `OIDC_HTTPS_PROXY`).
6. **Personalizzazioni**: elenco di eccezioni (`allowlist.yml`) e regole delle categorie particolari (`special_categories.yml`), da validare con il DPO.
7. **Primo avvio, in ordine**: `openbao`, `postgres`, `postgres-keys` → inizializzazione di OpenBao con i custodi (quote cifrate con PGP consigliate) → resto dello stack. **Langfuse**, due scelte:
   - *sulla VM*: profilo Compose `langfuse` e `CADDY_LANGFUSE_SITE=on` (Caddy pubblica l'interfaccia su `LANGFUSE_DOMAIN`);
   - *condiviso o esterno*: progetto dedicato «Pseudomania» con chiavi proprie (`LANGFUSE_HOST`, `LANGFUSE_PUBLIC_KEY`, `LANGFUSE_SECRET_KEY`), senza profilo `langfuse` e con `CADDY_LANGFUSE_SITE=off` (non servono `LANGFUSE_DOMAIN` né i certificati Langfuse); se l'host va raggiunto senza proxy, indicarlo in

`OUTBOUND_NO_PROXY`; se ha un certificato di CA interna, `EXTRA_CA_FILE`. Il job di Pseudomania cancella le tracce del solo progetto dedicato (30 giorni nel pilota, poi 7).

8. **Pacchetto dell'estensione**: chiave di firma dell'ente, ID stabile, `.crx` e `update.xml` pubblicati da Caddy sotto `/extension/` (§3.7).
9. **Controlli**: `curl https://pseudogate.ente.local/v1/health` deve rispondere `"status":"ok"`, `"detector":"ok"`, `"keys":"ok"`; `python -m pseudogate registri verifica`.
10. **Backup**: due backup separati (DB applicativo e key store) con chiavi diverse; pianificazione; prova di ripristino con **riapplicazione del registro delle cancellazioni**.
11. **Verifica del pilota** (`docs/verifica-pilota.md`) prima di abilitare gli utenti.

Permessi di rete dell'estensione: il server ammette via CORS l'origine dell'estensione (`CORS_ALLOW_ORIGIN_REGEX`, da restringere all'ID dell'ente); si consiglia **inoltre** di aggiungere l'host del server e dell'identity provider a `host_permissions` del manifest prima di impacchettare (`extension/README.md` §2.2, `docs/configurazione.md` §C.4).

3.5 Chiave di custodia e custodi

Procedura completa e modelli di verbale: `docs/custodi.md` e Allegato C di `governance/policy-uso-ia.md`. Strumento: `tools/custodi/custodi.py` (offline).

Postazione offline: portatile dedicato senza rete, Python ≥ 3.10 e il pacchetto `cryptography` installato da file scaricati in precedenza. Annotare nel verbale il commit da cui proviene lo strumento.

Operazione	Comando dello strumento	Chi	Quando
Generazione della chiave (RSA-OAEP-4096) e delle quote (predefinito 3, soglia 2), anche già cifrate per ciascun custode (`--cifra`)	`genera-chiave --out cerimonia/ --quote 3 --soglia 2`	3 custodi, testimone, DPO	una volta, prima del primo avvio
Verifica che due quote ricompongano la chiave e corrispondano alla pubblica	`verifica --quota … --quota … --pubblica escrow_public.pem`	2 custodi	almeno una volta l'anno e a ogni cambio di custode
Ridistribuzione delle quote (stessa chiave)	`ridistribuisci`	2 custodi	uscita di un custode, cambio di soglia
Recupero di un progetto dopo cambio PC	`ricifra --escrow … --dispositivo <codice>`	2 custodi + amministratore	su richiesta motivata approvata
Valori di segnaposto richiesti dall'autorità giudiziaria	`decifra-voci --escrow … --voci … --tag …`	2 custodi + amministratore	su richiesta scritta dell'autorità

Operazione	Comando dello strumento	Chi	Quando
Verbale	`verbale --tipo generazione|ridistribuzione|recupero|giudiziaria|cancellazione`	custodi	a ogni operazione

Regole essenziali: la chiave privata non viene mai scritta su disco; nessuna quota e nessuna chiave privata arriva sulla VM; nessun amministratore tiene due quote; le quote non si fotografano né si inviano per email; i file scambiati con il server viaggiano su una chiavetta dedicata, cancellata a fine operazione. Se una quota è stata esposta insieme a un'altra, la chiave va **sostituita** (nuova chiave + rotazione forzata di tutte le chiavi utente).

Le quote di sblocco di **OpenBao** (predefinito 5, soglia 3) sono **distinte** da quelle della chiave di custodia, anche se affidate alle stesse persone.

3.6 Configurazione di Claude Team

Decisioni vincolanti (DECISIONI.md, DPIA §2.1). Chi agisce: un **Owner** dell'organizzazione Claude Team. Percorsi ed etichette dettagliati, con le fonti, in `docs/configurazione.md` §A. **Le etichette dei menu non sono state verificate sulla console reale [DA VERIFICARE]**, salvo dove indicato.

#	Impostazione	Valore	Perché
1	Dominio verificato, **SSO** e «Require SSO»	attivi	si entra solo con l'account dell'ente e con l'accesso condizionato (§3.8)
2	**Memoria** di Claude (e riferimento alle chat passate)	**spenta**	riporterebbe segnaposto di altre conversazioni e contenuti fuori dal dizionario (rischio mitigato spegnendola)
3	**Ricerca web**	**attiva**, con misure	utile al lavoro; misure: verifica del sub-fornitore di ricerca, informativa, divieto di dati personali nelle richieste, misura nel pilota delle query con dati sfuggiti
4	**Connettori** e richieste di connettori dei membri	**spenti**	i contenuti dei connettori non passano dall'estensione
5	**Claude in Chrome**	**spento** (e bloccato anche con policy di Chrome)	agirebbe nel browser fuori dal controllo dell'estensione

#	Impostazione	Valore	Perché
6	**Voce** (modalità vocale, dettatura)	spenta se la console lo consente; in ogni caso microfono bloccato da estensione e policy di Chrome	la voce non passa dall'estensione
7	**Condivisione dei progetti**, progetti pubblici, link pubblici a chat e artifact	**spenti**	ogni dizionario appartiene a un solo utente: un collega vedrebbe solo segnaposto, un link pubblico li esporrebbe fuori
8	**Valutazioni / feedback** («Rate chats», in *Organization settings › Data and Privacy*, verificato su fonte Anthropic)	**spenti**	i feedback possono essere conservati fino a 5 anni e usati per l'addestramento
9	Esportazione dei propri dati da parte dei membri	**spenta**	evita copie fuori controllo
10	**Primary Owner**	solo su un **account di servizio** (es. `claude-owner@ente.it`) con **password a un custode e secondo fattore a un altro**	l'esportazione dei dati dell'organizzazione (*Data and privacy › Export Data*) è riservata al Primary Owner e comprende le conversazioni di tutti i membri: si usa solo su richiesta dell'autorità giudiziaria, con due custodi e verbale
11	Cowork, Claude Code, app desktop	spenti se la console lo consente	non coperti dall'estensione

Procedura per l'account Primary Owner: creare l'account di servizio nell'IdP con MFA obbligatoria; dividere password e secondo fattore tra due custodi; trasferire il ruolo **[DA VERIFICARE: procedura di trasferimento]**; gli amministratori operativi restano Owner/Admin con i propri account; verificare una volta l'anno che i due custodi riescano ad accedere, senza esportare.

3.7 Policy di Chrome

Dettagli ed esempi (GPO/registro, Intune, Console di amministrazione Google, Linux/macOS): `docs/configurazione.md` §C ed `extension/README.md` §2.

1. **ID stabile dell'estensione**: l'ente genera la propria chiave di firma (RSA 2048, custodita come un segreto: serve per ogni aggiornamento), la scrive nel manifest con `node scripts/extension-id.js <chiave.pem> --scrivi` e impacchetta il `.crx`.
2. **Installazione forzata**: `ExtensionInstallForcelist` = `ID_ESTENSIONE;https://pseudogate.ente.local/extension/update.xml` (oppure `ExtensionSettings` con `installation_mode: force_installed`, non entrambi).
3. **Configurazione gestita** (`3rdparty` → `extensions` → `ID_ESTENSIONE`):

Chiave	Valore nel pilota
`mode`	`"ente"`
`serverUrl`	`"https://pseudogate.ente.local"` (senza `/v1`)
`oidcIssuer`	issuer dell'IdP
`oidcClientId`	client pubblico dell'estensione (es. `pseudogate-extension`)
`oidcScopes`	`"openid profile"` (Entra ID: vedi `docs/configurazione.md` §B.1.b)
`oidcTokenType`	assente (= `access_token`) oppure `"id_token"`
`failClosed`	`true`
`allowDisable`	`false`
`sites`	`["claude.ai"]`

   `failClosed` e `allowDisable` si leggono **solo** dalla policy: il server non può indebolirli.

4. **Policy di contorno**:

Policy	Valore	Scopo
`IncognitoModeAvailability`	`1`	le estensioni non girano in incognito
`BrowserGuestModeEnabled`	`false`	né in modalità ospite
`BrowserAddPersonEnabled`	`false`	niente nuovi profili
`DeveloperToolsAvailability`	`2`	impedisce di manomettere l'estensione
`AudioCaptureAllowed`	`false` (o `AudioCaptureAllowedUrls` senza claude.ai)	microfono
`ExtensionSettings`	blocco dell'estensione «Claude» (Claude in Chrome) e, se si vuole, delle altre estensioni su claude.ai	

Policy	Valore	Scopo
`CloudAPAuthEnabled`	`1`	solo con l'accesso condizionato di Entra ID

5. **Verifica su un PC**: `chrome://policy` → **Ricarica criteri** (stato *OK*); `chrome://extensions` → Pseudomania «Installata dall'amministratore».

Attenzione: senza la policy l'estensione parte in Personal edition. La policy va applicata a **tutti** i profili Chrome dei PC interessati.

3.8 SSO e accesso condizionato

Due integrazioni distinte (`docs/configurazione.md` §B):

1. **Estensione → server Pseudomania**: client OIDC **pubblico**, *authorization code* con **PKCE S256**, redirect URI `https://ID_ESTENSIONE.chromiumapp.org/oidc`, refresh token abilitato. Sul server `OIDC_ISSUER` (claim `iss` esatto) e `OIDC_AUDIENCE` (claim `aud` atteso). Con Keycloak serve un mapper *Audience* nell'access token; con Entra ID si usa l'`id_token` oppure un'API esposta. L'identità non viene salvata: il server conserva solo uno pseudonimo HMAC.
2. **Utenti → Claude Team**: SSO SAML (o OIDC) tramite la procedura di Anthropic, assegnato al solo gruppo del pilota, con **accesso condizionato**: solo da dispositivi gestiti e/o dalla rete interna (Entra: *Conditional Access* con dispositivo conforme; Keycloak: limitazione di rete o certificato del dispositivo). Così l'estensione non si aggira usando un PC personale.

Per l'utente il login all'estensione avviene dal pulsante **Accedi** nella finestra che si apre cliccando il pulsante di Pseudomania (normalmente in modo silenzioso). Nell'Enterprise edition il pulsante è **bloccato su acceso**: la stessa finestra spiega «Protezione sempre attiva: Pseudomania è gestito dalla tua organizzazione e non può essere disattivato.» e la scorciatoia Alt+Maiusc+P non ha effetto. I token restano nella memoria della sessione del browser.

3.9 Proxy

Obiettivo: claude.ai raggiungibile **solo** da Chrome gestito (`docs/configurazione.md` §F).

- consentire `claude.ai`, i domini collegati (elenco di partenza da confermare con i log del proxy nella prima settimana **[DA VERIFICARE]**) e l'IdP;
- consentire claude.ai solo al gruppo autenticato del pilota e, se possibile, solo al Chrome gestito (User-Agent, PAC distribuito solo a Chrome verso una porta dedicata, certificato del dispositivo): nessuna opzione è perfetta da sola;
- non ispezionare il traffico verso il server Pseudomania e non registrare i corpi delle richieste verso claude.ai;
- valutare le **restrizioni per tenant** di Anthropic (intestazione inserita dal proxy che ammette solo l'organizzazione dell'ente) **[DA VERIFICARE: disponibilità sul piano Team]**;

- la VM di Pseudomania **non** deve raggiungere claude.ai: in uscita solo verso l'IdP (ed eventualmente un Langfuse condiviso).

3.10 MDM e blocco delle app

L'estensione protegge **solo** Chrome. Vanno quindi bloccate:

- **Claude Desktop** sui PC (AppLocker o App Control for Business via GPO/Intune; su macOS restrizioni dell'MDM) **[DA VERIFICARE: percorsi e identificativi dell'app]**;
- **app Claude** sui telefoni aziendali Android (pacchetto `com.anthropic.claude`, non approvato o bloccato in Google Play gestito / Intune / API Android Management);
- sui dispositivi personali (BYOD) l'ente non può bloccare app: la protezione viene dall'**accesso condizionato** dell'SSO, che rifiuta i dispositivi non gestiti.

3.11 Durate di conservazione

Fonte vincolante: DECISIONI.md; motivazioni e fonti normative nel capitolo 5 (§5.4) e nella DPIA §2.5. Valori regolabili nel `.env` del server (`docs/installazione-ente.md` §18).

Dato	Durata
Dizionario delle chat	30 giorni dall'ultimo uso; nessun recupero dopo cambio PC
Dizionario dei progetti	durata del progetto + 30 giorni dall'ultimo uso; scade senza **conferma annuale** dell'utente nel pannello; recupero tramite custodi solo su richiesta motivata
Chat nuove non ancora salvate (scope `pending:`)	24 ore
Voci non caricate dall'estensione	10 minuti (poi non ripristinabili)
Registro azioni (`audit_events`)	90 giorni in forma pseudonima, poi solo aggregati anonimi (conteggi per giorno/ufficio senza utente)
Tracce Langfuse	30 giorni durante il pilota, poi 7 (job di Pseudomania)
Backup del database applicativo	rotazione ≤ 35 giorni (7 giornalieri + 4 settimanali), una copia offline
Key store e suoi backup	backup separati, rotazione 14 giorni
Copie di custodia delle chiavi utente (escrow)	stessa vita della chiave: rotazione automatica ogni 90 giorni, distrutte con la chiave
Registri tecnici degli accessi di amministratori e custodi, registro delle cancellazioni	24 mesi, in sola aggiunta, con catena di hash
Verbali dei custodi e richieste dell'autorità	protocollati, secondo il massimario dell'ente
Blocco per autorità giudiziaria	sospende la cancellazione **solo** dei dati indicati, fino a revoca, registrato

Dato	Durata
Conversazioni su claude.ai (piano Team)	a tempo indeterminato salvo cancellazione **[DA VERIFICARE: tempi di rimozione dal back-end]**

Dopo **ogni ripristino** da backup il registro delle cancellazioni va **riapplicato** prima di rimettere in servizio il sistema (`scripts/riapplica-cancellazioni.sh`).

4. Uso quotidiano

Questo capitolo è per **chi usa claude.ai** con Pseudomania, in entrambe le edizioni. Dove il comportamento è diverso è indicato **(Personal)** o **(Enterprise)**.

> I nomi dei pulsanti di claude.ai citati qui possono cambiare con gli aggiornamenti del sito **[DA VERIFICARE sull'interfaccia reale]**. I testi dei messaggi di Pseudomania sono invece quelli dell'estensione.

4.1 Prima di iniziare: controlla lo stato

- Sopra la casella di scrittura deve esserci la **barra di Pseudomania** con la scritta «Pseudomania attivo: i dati personali vengono pseudonimizzati prima dell'invio».
- **(Enterprise)** Se compare «Accesso richiesto: effettua il login a Pseudomania dal pulsante dell'estensione», clic sul pulsante di Pseudomania → **Accedi**. Il pulsante è sempre acceso: la protezione non si può spegnere.
- **(Personal)** Il badge sul pulsante deve essere **ON** verde per la conversazione aperta (§2.5). Se compare il banner «Vuoi attivare Pseudomania per questa conversazione?», scegli **Attiva** (o **Continua senza protezione** solo per conversazioni senza dati di terzi): vedi §2.6.
- Se la barra non c'è, o compare «Pagina non riconosciuta da Pseudomania», **non inviare dati personali** e vedi il capitolo 6.

4.2 Scrivere e inviare un messaggio

Scrivi come al solito e premi **Invio** (o il pulsante di invio). Per un attimo compare «Pseudonimizzazione in corso…», poi il testo nella casella viene sostituito con la versione con i segnaposto e parte.

- Nel fumetto del tuo messaggio vedrai i **segnaposto** (`[FULLNAME_1]`, `[CF_1]`…): è ciò che ha ricevuto Claude.
- Nel **primo messaggio** di ogni conversazione vedrai anche l'istruzione fissa per Claude: «I testi contengono segnaposto tra parentesi quadre come [FULLNAME_n] o [CF_n] (n = numero). Riportali esattamente come sono…». È normale.
- **Modificare un messaggio già inviato**: la casella di modifica mostra i segnaposto (è il testo realmente inviato). Puoi aggiungere testo nuovo: verrà pseudonimizzato al reinvio.
- **Rigenerare** una risposta: il messaggio rinviato è già pseudonimizzato.

4.3 Allegati

Trascina, incolla o scegli i file come sempre: l'estensione li intercetta prima del caricamento.

Formato	(Personal)	(Enterprise)
DOCX, XLSX	pseudonimizzati nell’estensione	pseudonimizzati dal server
TXT, CSV, MD	pseudonimizzati	pseudonimizzati
PDF	inviato come **file di testo pseudonimizzato (.txt)** con avviso (impaginazione e immagini non partono)	pseudonimizzato dal server
Immagini, altri formati	**bloccati**	**bloccati**

Anche il **nome del file** può contenere dati personali: viene pseudonimizzato in entrambe le edizioni (per esempio `Lettera_Mario_Rossi.docx` parte come `Lettera_[FULLNAME_1].docx`). **(Personal)** Nel nome del file i trattini bassi sono letti come spazi, così «Mario_Rossi» viene riconosciuto come nome; quando il nome viene ripristinato (per esempio al download) compare con lo spazio: `Lettera_Mario Rossi.docx`. Un file troppo grande viene rifiutato («Il file supera la dimensione massima consentita…»).

Testo lungo incollato: claude.ai può trasformarlo in un allegato; l’estensione lo controlla comunque.

4.4 Progetti

Nei progetti di claude.ai vengono pseudonimizzati anche le **istruzioni del progetto** e i **file della conoscenza** del progetto. Tutte le chat dentro lo stesso progetto condividono **lo stesso dizionario**: lo stesso nome ha lo stesso segnaposto in tutte le chat del progetto.

- I dizionari dei progetti durano più a lungo di quelli delle chat (vedi §4.11, §2.8 e §3.11).
- **Non condividere** progetti con i colleghi: ogni dizionario appartiene a una sola persona e i colleghi vedrebbero solo segnaposto **(Enterprise: la condivisione è spenta dall’ente)**.

4.5 La risposta con i dati ripristinati

Mentre Claude scrive, l’estensione sostituisce i segnaposto con i **valori reali**, solo nella tua pagina:

Aspetto	Significato
testo evidenziato in **verde**	valore ripristinato dal dizionario
segnaposto evidenziato in **rosso** + avviso «… segnaposto nella risposta non sono nel dizionario»	Claude ha scritto un segnaposto che non esiste (inventato o modificato) oppure di un’altra conversazione: **non fidarti** di quel punto
segnaposto in **grigio** + avviso «… non sono ripristinabili»	il dizionario era stato cifrato su un altro computer (vedi §4.10)

- **Copiare**: selezionando e copiando il testo, o con i pulsanti «Copia» del sito, negli appunti arrivano i **valori reali**.

- **Scaricare** un file DOCX, XLSX o di testo generato da Claude: i valori vengono ripristinati nel file. Se non è possibile, il file viene scaricato con i segnaposto e un avviso. **(Personal)** I PDF non vengono ripristinati.
- **Artifact** mostrati in un riquadro separato: **non** vengono ripristinati. Pubblicare o condividere un artifact espone solo segnaposto.

Verifica sempre la risposta prima di usarla: l'IA può sbagliare, e un segnaposto spostato può attribuire un dato alla persona sbagliata.

4.6 Anteprima prima dell'invio (Ctrl+Maiusc+Invio)

Per controllare **prima** che cosa partirà, premi **Ctrl+Maiusc+Invio** invece di Invio. Si apre la finestra «Anteprima di ciò che verrà inviato» con due colonne, «Testo originale» e «Testo inviato a Claude». Scegli **Invia** se va bene, **Annulla** per correggere.

Usala soprattutto con testi lunghi, elenchi di persone, testi con nomi stranieri o insoliti.

4.7 Il pannello di ispezione

Sotto ogni messaggio inviato compare un contrassegno, per esempio «3 dati protetti» (oppure «nessun dato personale»). Cliccandolo si apre a lato il pannello **«Ispezione Pseudomania»** (in alternativa: **(Personal)** clic destro sul pulsante di Pseudomania → **Apri pannello di ispezione**; **(Enterprise)** clic sul pulsante → **Apri pannello di ispezione**).

Il pannello mostra:

- **Originale (solo su questo computer)** e **Inviato a Claude**, affiancati;
- **Dati sostituiti**: l'elenco dei segnaposto e del tipo di dato;
- **Mostra le risposte con i segnaposto**: come le ha scritte davvero Claude;
- i pulsanti di **segnalazione** (§4.8) e, dopo un invio bloccato, **Segnala blocco errato** (§4.9);
- **Elimina i dati di questa conversazione / di questo progetto**: cancella il dizionario (definitivo: le risposte già ricevute non saranno più ripristinate);
- **(Enterprise)** la **conferma annuale** del progetto (§4.11), il **recupero** da un altro computer (§4.10) e l'identificativo abbreviato della chiave di cifratura attiva.

Il contenuto «originale/inviato» resta solo nella memoria della sessione: chiudendo il browser si perde e i contrassegni sui messaggi vecchi non ricompaiono.

4.8 Segnalazioni

Dal pannello di ispezione:

- **Segnala dato non riconosciuto**: un dato personale è partito senza essere sostituito (falso negativo);
- **Segnala mascheramento errato**: è stato sostituito qualcosa che non era un dato personale (falso positivo).

Nel campo «Nota facoltativa» **non scrivere dati reali**: usa i segnaposto o descrivi il tipo di dato («un cognome straniero», «un numero di pratica»). La nota viene comunque ripulita dai valori noti.

- **(Enterprise)** la segnalazione va al server dell'organizzazione e serve a migliorare il rilevamento. Se è partito un dato reale, avvisa **anche** il referente indicato dal regolamento: può essere una violazione di dati da valutare.
- **(Personal)** la segnalazione resta nel registro locale («Segnalazione salvata nel registro locale»). Se è partito un dato di un cliente, cancella la chat e valuta se è una violazione (vedi §5.2, punto 7 del modello light).

4.9 Blocchi per categorie particolari di dati

Se il testo o un allegato sembra contenere **dati sanitari, giudiziari o altre categorie particolari** (artt. 9-10 GDPR), compare il banner rosso **«Invio bloccato»** con un messaggio del tipo: «Il contenuto sembra includere dati relativi alla salute (art. 9 GDPR), ad esempio «certificato medico». […] Rimuovi o generalizza questi riferimenti e riprova. Se pensi che il blocco sia sbagliato, segnalalo con il pulsante «Segnala blocco errato» nel pannello laterale di Pseudomania».

- Il blocco **non si può forzare**.
- Riformula senza quei riferimenti o, se servono davvero, **non usare Claude** per quel testo.
- Se pensi che il blocco sia sbagliato (per esempio una circolare generale sulle assenze), usa il pulsante **«Segnala blocco errato»**: compare nel banner rosso e nel pannello di ispezione, dove la sezione dedicata mostra «Ultimo invio bloccato (categoria «…») alle …». Funziona **anche se il messaggio non è partito** e non invia il testo: registra solo la categoria del blocco («Segnalazione inviata. Grazie.»; **(Personal)** la segnalazione resta nel registro locale). **(Enterprise)** Per casi urgenti puoi rivolgerti anche all'help desk.
- Il blocco non sostituisce il tuo giudizio: i dati particolari **non vanno inseriti** anche quando l'estensione non li riconosce.

Altri blocchi possibili: server o servizio di riconoscimento non disponibile **(Enterprise)**, pagina non riconosciuta, testo che non è stato possibile sostituire nella casella. In tutti questi casi l'invio è fermato per sicurezza: vedi il capitolo 6.

4.10 Cambio PC: segnaposto non ripristinabili e recupero

Il dizionario è cifrato con una chiave che **non lascia il tuo browser**. Se cambi computer, profilo Chrome o cancelli i dati del browser, le conversazioni precedenti mostrano segnaposto **grigi** con l'avviso «… segnaposto non sono ripristinabili: il dizionario è stato cifrato su un altro computer».

- **Chat**: il recupero **non è previsto** (in nessuna edizione).
- **Progetti (Personal)**: nessun recupero.
- **Progetti (Enterprise)**: recupero possibile **su richiesta motivata**, approvata dal dirigente:

1. apri il progetto sul nuovo PC, poi il pannello di ispezione → sezione «Recupero da un altro computer (solo progetti)» → **Prepara il recupero**;
2. il pannello mostra «Codice del dispositivo da comunicare all'assistenza: …»: apri un ticket all'help desk con il codice e il motivo;
3. due custodi ricifrano offline la tua vecchia chiave per questo computer; l'amministratore la carica;
4. entro un minuto l'estensione la scarica da sola (oppure **Verifica chiavi recuperate**): i valori tornano visibili. La chiave recuperata resta disponibile per 7 giorni: non cambiare di nuovo PC nel frattempo.

Le voci create negli ultimi minuti prima del cambio (non ancora caricate entro 10 minuti) possono restare non ripristinabili.

4.11 Conferma annuale dei progetti (Enterprise)

Ogni progetto ha una scadenza di conferma. Nel pannello di ispezione, sezione **«Conferma annuale del progetto»**, compare: «Senza conferma il dizionario di questo progetto scade il …». Se il progetto è ancora in uso, clic su **«Il progetto è ancora in uso: conferma»** → «Progetto confermato per un altro anno.». Quando la scadenza si avvicina compare «La conferma annuale scade a breve.».

Senza conferma (o dopo 30 giorni senza uso) il dizionario viene cancellato e le risposte del progetto non sono più ripristinabili. Cancella tu i progetti che non ti servono più.

(Personal) Non c'è conferma: i dizionari dei progetti restano finché non li elimini dal pannello.

4.12 Che cosa non fare

1. **Non scrivere dati personali nelle preferenze del profilo Claude** (istruzioni personalizzate, stile, nome con cui farti chiamare oltre al nome di battesimo): **non passano da Pseudomania**.
2. **Non chiedere ricerche web su persone** e non mettere nomi, codici o indirizzi nelle richieste di ricerca: le query sono elaborate da un sub-fornitore del servizio.
3. **Non usare l'app desktop o mobile di Claude**, altri browser o la navigazione in incognito per dati personali: lì Pseudomania non c'è.
4. **(Enterprise)** Non accedere all'account dell'ente da **dispositivi personali** o non gestiti, e non usare account personali per dati dell'ente (nemmeno con la Personal edition).
5. **Non chiedere a Claude di modificare, spiegare, tradurre o "indovinare" i segnaposto**, e non fornire indizi per risalire al valore originale.
6. **Non inserire categorie particolari** (salute, reati, opinioni politiche…), dati di minori, credenziali, password, atti riservati o coperti da segreto.
7. **Non aggirare l'estensione** (scrivere i dati in forma alterata per evitarne il riconoscimento, incollare tramite strumenti esterni, usare un altro profilo).
8. **Non inviare feedback** (pollice su/giù) su chat con dati di terzi.

9. **(Personal)** Non spegnere la protezione in una conversazione con dati di terzi e non scegliere «Continua senza protezione» per abitudine: riattivare non ripulisce ciò che è già partito.
10. **Non fidarti ciecamente**: elimina o generalizza i dettagli che identificano senza nome (ruolo unico, data e luogo precisi, numero di pratica, fatto noto).

4.13 Domande frequenti

Claude vede i miei dati? Vede il testo con i segnaposto. Vede però tutto ciò che Pseudomania non ha riconosciuto e tutto ciò che non passa dall'estensione (§1.5).

Perché nel mio messaggio vedo `[FULLNAME_1]` invece del nome? Perché è ciò che è stato inviato. Il nome reale è nel dizionario sul tuo computer (o cifrato sul server, Enterprise).

Lo stesso nome ha sempre lo stesso segnaposto? Sì, all'interno della stessa conversazione o dello stesso progetto. In un'altra conversazione la numerazione riparte.

Claude ha scritto `[FULLNAME_3]` in rosso: che cosa significa? Il segnaposto non esiste nel dizionario: Claude lo ha inventato o alterato. Controlla quel punto e, se serve, chiedi di riscrivere usando solo i segnaposto presenti.

Posso spegnere Pseudomania? (Personal) Sì, per la sola conversazione aperta: clic sul pulsante o Alt+Maiusc+P. Si spegne solo l'uscita: i segnaposto delle risposte vengono comunque ripristinati. La scelta resta salvata per quella conversazione. **(Enterprise)** No: «Protezione sempre attiva: Pseudomania è gestito dalla tua organizzazione e non può essere disattivato.»

Ho spento la protezione e poi l'ho riaccesa: ciò che ho inviato nel frattempo è protetto? No. Quanto inviato con la protezione spenta è già arrivato a Claude in chiaro; se conteneva dati di terzi, cancella la conversazione e valuta se si tratta di una violazione.

Il server è irraggiungibile e non posso inviare: posso aggirare? No **(Enterprise)**: l'invio è bloccato per tutelare i dati. Riprova più tardi o contatta l'assistenza.

Ho cambiato PC e vedo segnaposto grigi. Vedi §4.10.

Il PDF è arrivato a Claude come .txt. È previsto nella Personal edition (§2.7).

L'amministratore può leggere le mie conversazioni? (Enterprise) No in via ordinaria: il server non conserva testi (solo un registro minimo con impronte e uno pseudonimo, e tracce pseudonimizzate per pochi giorni) e i dizionari sono cifrati con la tua chiave. I contenuti si estraggono **solo su richiesta dell'autorità giudiziaria**, con due custodi e verbale (regolamento, art. 10).

Cancellare la chat su claude.ai cancella anche il dizionario? No: elimina il dizionario dal pannello di ispezione (oppure attendi la scadenza). E viceversa: eliminare il dizionario non cancella la chat su claude.ai.

La dettatura vocale non funziona. È disattivata da Pseudomania («La dettatura vocale è disattivata da Pseudomania»): la voce non passerebbe dal riconoscimento.

5. Creare una policy

Pseudomania da sola non basta: servono **regole scritte** su che cosa si può e non si può fare con l'IA, chi fa che cosa, per quanto si conservano i dati e che cosa succede quando qualcosa va storto. Questo capitolo guida alla stesura in due versioni:

Modello	Per chi	Base	Documenti
Light	professionista, studio, piccola organizzazione con la **Personal edition**	`governance/policy-light.md`	una pagina di regole firmata, più alcune verifiche
Strutturato	**ente pubblico** (o impresa) con l'**Enterprise edition**	`governance/policy-uso-ia.md`, `governance/dpia.md`, `governance/checklist-adempimenti.md`	regolamento, informativa, DPIA, accordo sindacale, procedura dei custodi, procedura di cancellazione, durate

> **Modelli, non consulenza legale.** I testi sono bozze da adattare con il proprio DPO o consulente. La responsabilità delle scelte resta interamente di chi adotta il sistema (capitolo 0). I riferimenti marcati **[DA VERIFICARE]** non sono stati controllati sul testo ufficiale. Nei modelli, le parti tra parentesi quadre `[ ]` vanno compilate.

5.1 Prima di scrivere: tre domande

1. **Chi è il titolare?** Il professionista per i dati dei propri clienti (o il cliente, se il professionista agisce come responsabile); l'ente o l'impresa per i dati trattati dai dipendenti.
2. **Quali dati entreranno in Claude?** Se sono probabili dati sanitari, giudiziari, di minori o altre categorie particolari, l'uso va escluso o valutato a fondo (DPIA).
3. **Quale piano di Claude?** I piani consumer (Free, Pro, Max) hanno condizioni diverse da quelli commerciali (Team, Enterprise): verificare uso per l'addestramento, conservazione, DPA.

5.2 Modello «light» (professionista o piccola organizzazione)

Passi

1. **Leggi** le avvertenze (capitolo 0) e le condizioni del tuo piano Claude; conserva copia delle condizioni e, se disponibile, del DPA.
2. **Configura** Claude come indicato al §2.6 (addestramento, memoria, connettori, feedback).
3. **Compila** il modello qui sotto (copiato da `governance/policy-light.md`), adattandolo.
4. **Aggiorna** l'informativa privacy dello studio, se usi l'IA su dati dei clienti.

5. **Valuta** se serve una DPIA (art. 35 GDPR): di regola sì se tratti su larga scala dati delicati o categorie particolari (che comunque non dovrebbero entrare in Claude).
6. **Firma e data** il documento; rileggilo almeno una volta l’anno.

Checklist light

- ☐ Piano Claude scelto e condizioni conservate (data: `[ ]`)
- ☐ Uso delle chat per l’addestramento disattivato (se il piano lo prevede)
- ☐ Memoria e connettori non necessari disattivati
- ☐ Pseudomania installata e verificata (prova del §2.5)
- ☐ Regole d’uso compilate e firmate
- ☐ Informativa ai clienti aggiornata (se pertinente)
- ☐ Valutazione sulla DPIA annotata (fatta / non necessaria, perché: `[ ]`)
- ☐ Procedura in caso di dato sfuggito conosciuta (punto 7)
- ☐ Data della prossima revisione: `[ ]`

Modello da compilare

```
REGOLE ESSENZIALI PER L'USO DELL'IA GENERATIVA CON PSEUDOMANIA PERSONAL EDITION
(modello — non è consulenza legale; la responsabilità resta di chi adotta e usa il sistema)

Titolare / professionista: [nome, studio o organizzazione, contatti]
Versione e data: [ ]

1. A COSA SI APPLICA
Uso di Claude (claude.ai) [piano: Pro / Max / Team] per il mio lavoro, tramite Chrome con
l'estensione Pseudomania Personal edition e l'app desktop Rizzo-PII sul mio computer.
Rilevamento, dizionario dei segnaposto e registro restano sul mio computer, cifrati.
Sono titolare dei trattamenti che ne derivano (o li svolgo per conto del cliente, se
responsabile).

2. COSA FACCIO SEMPRE
2.1 Tengo Pseudomania attiva e, se Rizzo-PII non risponde, non invio finché non l'ho
riavviato.
2.2 Prima di inviare documenti lunghi uso l'ispezione o l'anteprima e controllo cosa parte.
2.3 Tolgo o generalizzo i dettagli che rendono riconoscibile una persona anche senza nome
    (ruolo unico, data e luogo precisi, fatto noto, numero di pratica).
2.4 Verifico sempre le risposte prima di usarle.
2.5 Cancello le chat e i progetti che non mi servono più.

3. COSA NON FACCIO MAI
3.1 Non inserisco dati sanitari, giudiziari o altre categorie particolari (artt. 9-10
GDPR),
    né dati di minori, anche se pseudonimizzati, salvo valutazione specifica documentata.
3.2 Non scrivo dati personali nelle preferenze del profilo di Claude né nelle richieste di
    ricerca web.
3.3 Non chiedo a Claude di modificare, spiegare o ricostruire i segnaposto.
3.4 Non inserisco password, chiavi, segreti professionali non necessari o informazioni
    riservate che il cliente non ha autorizzato.
3.5 Non invio feedback (pollici) su chat con contenuti di clienti.

4. IMPOSTAZIONI DI CLAUDE
- Dati non usati per l'addestramento [verificare le condizioni del proprio piano].
- Memoria disattivata; connettori e integrazioni non necessari disattivati.
- Ricerca web solo se serve, senza dati personali nelle richieste.

5. CONSERVAZIONE
Dizionario delle chat: 30 giorni dall'ultimo uso. Dizionario dei progetti: finché non li
elimino. Registro locale: [es. 90 giorni]. Le conversazioni su claude.ai restano presso il
fornitore secondo le sue condizioni finché non le cancello.

6. CLIENTI E INTERESSATI
- Valuto se informare i clienti dell'uso di strumenti di IA (informativa dello studio
  [aggiornare]; per le professioni intellettuali v. art. 13 L. 132/2025 [DA VERIFICARE]).
- Verifico le condizioni del fornitore (DPA, trasferimenti extra-UE) e le conservo.
- Se l'uso è rilevante per i rischi degli interessati, valuto una DPIA (art. 35 GDPR).

7. SE QUALCOSA VA STORTO
Se è partito un dato personale non mascherato: cancello la chat, annoto data e contenuto
(senza ricopiare il dato), valuto se è una violazione di dati da notificare al Garante
entro
72 ore (art. 33 GDPR) e, se il rischio è elevato, da comunicare agli interessati (art. 34).
Se il cliente è il titolare, lo avviso senza ritardo.
```

```
8. FORMAZIONE E REVISIONE
Leggo il manuale di Pseudomania e aggiorno le mie competenze sull'IA (art. 4 AI Act).
Rivedo queste regole almeno una volta l'anno o quando cambiano il servizio o le sue
condizioni.

[Luogo, data, firma]
```

5.3 Modello «strutturato» (ente pubblico)

Il percorso è quello della `governance/checklist-adempimenti.md` (23 voci). Qui è riordinato in passi; ogni passo indica il documento di partenza, chi lo cura e che cosa deve contenere.

Passo 1 – Gruppo di lavoro e perimetro

- **Chi**: titolare (o dirigente delegato), DPO, RTD, ufficio personale, amministratori di sistema, ufficio contratti.
- **Che cosa**: atto che individua il servizio IA autorizzato (nel pilota: Claude Team, solo chat con progetti, allegati e ricerca web), gli utenti del pilota (`[n.]`, con atto `[ ]`), la durata, le fasi successive escluse finché regolamento e DPIA non sono aggiornati.

Passo 2 – Verifiche sul fornitore

Riferimento: `governance/verifiche-fase0.md`.

☐ Commercial Terms e **DPA** di Anthropic vigenti; entità contraente per il SEE (Anthropic Ireland, Limited); notifica delle violazioni; cancellazione a fine contratto
☐ **Trasferimenti** extra-UE: clausole contrattuali tipo e **valutazione d’impatto del trasferimento (TIA)** documentata; Data Privacy Framework **[DA VERIFICARE]**
☐ **Sub-responsabili**: elenco ufficiale allegato alla DPIA, incluso il fornitore della ricerca web
☐ **Qualificazione ACN** del servizio cloud, ove richiesta **[DA VERIFICARE]**
☐ Conservazione delle chat sul piano Team e tempi di rimozione dopo la cancellazione **[DA VERIFICARE con Anthropic]**
☐ Dopo la prova tecnica: **lettera ad Anthropic** sulla compatibilità dell’estensione con i termini del servizio (modello in `verifiche-fase0.md` §5)

Passo 3 – DPIA

Riferimento: `governance/dpia.md` (bozza completa: necessità, descrizione, flussi, durate, rischi, misure, verifiche sul fornitore, parere del DPO, opinione degli interessati, piano d’azione).

Da completare:

☐ contesto dell’ente, uffici, numero di utenti, tipi di documenti
☐ valutazione dei rischi con i dati reali del pilota (test di rilevamento sul corpus dell’ente, soglia di accettazione `[ ]`)

☐ **parere del DPO** (art. 35, par. 2, GDPR)
☐ **opinione dei rappresentanti dei lavoratori** (art. 35, par. 9) — utile coordinarla con il passo 6
☐ se resta un rischio residuo alto: **consultazione preventiva del Garante** (art. 36)
☐ approvazione e data di riesame

Passo 4 – Regolamento d'uso

Riferimento: `governance/policy-uso-ia.md` (bozza 0.3). Struttura e campi da compilare:

Articolo	Contenuto	Da compilare
Premessa	quadro normativo (GDPR, Codice privacy, AI Act art. 4, L. 132/2025 art. 14, art. 4 L. 300/1970, provv. Garante, codici di comportamento)	linee guida AgID **[DA VERIFICARE stato]**
1 Oggetto e ambito	servizio autorizzato, solo Chrome gestito con Pseudomania, utenti; esclusione della Personal edition dai trattamenti dell'ente	`[atto di individuazione degli utenti]`
2 Definizioni	segnaposto, dizionario cifrato, copia di custodia, quasi-identificatori, registro minimo, account di custodia, custodi	—
3 Principi	uso strumentale e di supporto; output da verificare; minimizzazione	—
4 Usi consentiti	redazione, sintesi, traduzione, analisi di documenti pubblici, bozze di atti, fogli di calcolo con dati comuni pseudonimizzati	adattare agli uffici
5 Usi vietati	categorie particolari e dati giudiziari; decisioni automatizzate; dispositivi personali e app; account personali; elusione; manipolazione dei segnaposto; preferenze del profilo; ricerche web con dati personali; credenziali e atti riservati; funzioni disattivate; pubblicazione senza revisione; feedback	casi ad alto rischio AI Act **[DA VERIFICARE]**
6 Quasi-identificatori	cautele prima dell'invio, ispezione, segnalazioni	—
7 Obblighi degli utenti	formazione, SSO, verifica, conferma annuale dei progetti, cambio PC, segnalazioni	`[indirizzo per le segnalazioni]`

Articolo	Contenuto	Da compilare
8 Ruoli	titolare, DPO, dirigente, RTD, amministratori di sistema, custodi, responsabili esterni	`[nomi o uffici]`
9 Misure tecniche	estensione forzata, fail-closed, cifratura, impostazioni di Claude, blocco app, SSO, proxy, registri	—
10 Accesso ai contenuti	registro e tracce solo per sicurezza e qualità, mai per valutare la prestazione; contenuti solo su richiesta dell'autorità giudiziaria con procedura dei custodi	`[estremi del regolamento di videosorveglianza usato come modello]`
11 Conservazione	tabella del §5.4	—
12 Fornitori e trasferimenti	DPA, SCC, ACN, lettera dopo la prova tecnica	—
13 Formazione	alfabetizzazione IA (art. 4 AI Act), moduli	`[ore]`
14 Trasparenza	sintesi sul sito istituzionale	`[sezione del sito]`
15 Incidenti e violazioni	che cosa è un incidente, segnalazione, artt. 33-34 GDPR, rotazione forzata, ridistribuzione quote	`[referente]`, `[procedura data breach]`, NIS2 **[DA VERIFICARE]**
16 Sanzioni	disciplinare nei limiti dell'art. 4, c. 3, L. 300/1970 e dell'accordo	`[con le organizzazioni sindacali]`
17 Condizioni di avvio e revisione	DPIA, accordo, registro, informativa, custodi, prove, verifiche; riesame entro 12 mesi	—

Passo 5 – Informativa ai dipendenti (Allegato A)

Riferimento: Allegato A di `governance/policy-uso-ia.md` (art. 13 GDPR). Checklist dei contenuti:

☐ titolare e DPO con contatti `[ ]`
☐ dati trattati: account e accesso; registro minimo (pseudonimo HMAC, impronte SHA-256, **nessun testo**); tracce pseudonimizzate; dizionario cifrato nel browser; conversazioni presso Anthropic
☐ avviso esplicito: **preferenze del profilo e richieste di ricerca web non sono filtrate**
☐ finalità e basi giuridiche (tabella), esclusione della valutazione della prestazione
☐ accesso ai contenuti solo su richiesta dell'autorità giudiziaria, con due custodi e verbale
☐ destinatari (incluso il sub-fornitore di ricerca web), trasferimenti extra-UE
☐ durate (§5.4), diritti, reclamo al Garante
☐ assenza di decisioni automatizzate; informazione sull'uso dell'IA nel rapporto di lavoro
[DA VERIFICARE: art. 11 L. 132/2025 e art. 1-bis d.lgs. 152/1997]

☐ consegna documentata a ciascun utente prima dell'abilitazione

Passo 6 – Accordo sindacale (art. 4 L. 300/1970)

Il registro minimo (90 giorni), le tracce Langfuse, l'esportazione tramite l'account Primary Owner e la procedura dei custodi sono strumenti dai quali può derivare un **controllo a distanza** dei lavoratori. Secondo il documento di indirizzo del Garante del 6/6/2024 (metadati della posta elettronica, applicato per analogia) la conservazione oltre 21 giorni richiede le garanzie dell'art. 4, c. 1, L. 300/1970: **accordo con le rappresentanze sindacali** o, in mancanza, **autorizzazione dell'Ispettorato nazionale del lavoro**. Lo Statuto si applica alle pubbliche amministrazioni **[DA VERIFICARE: art. 51, c. 2, d.lgs. 165/2001]**.

Schema dei contenuti dell'accordo (da negoziare; non è un testo approvato):

```
ACCORDO AI SENSI DELL'ART. 4, COMMA 1, L. 300/1970
sull'uso del servizio Claude Team tramite Pseudomania Enterprise edition — SCHEMA

Parti: [Ente] e [RSU / organizzazioni sindacali]          Data: [ ]

1. Oggetto: strumenti e trattamenti coperti
   - registro minimo del server (pseudonimo HMAC, ufficio, azioni, conteggi, impronte SHA-
256,
     nessun testo) — conservazione 90 giorni, poi solo aggregati anonimi;
   - tracce di osservabilità (testi pseudonimizzati) — 30 giorni nel pilota, poi 7;
   - esportazione dei dati di Claude Team tramite account di custodia;
   - procedura dei custodi (recupero progetti, richieste dell'autorità giudiziaria).
2. Finalità ammesse: sicurezza, verifica del funzionamento e qualità del rilevamento,
   accertamenti su richiesta dell'autorità giudiziaria.
3. Finalità escluse: valutazione della prestazione, controllo dell'attività lavorativa,
   uso disciplinare salvo [limiti concordati ex art. 4, c. 3].
4. Accessi: amministratori solo in forma aggregata o pseudonima; contenuti solo su
richiesta
   scritta dell'autorità giudiziaria, due custodi, estrazione della sola parte richiesta,
   distruzione del resto, verbale.
5. Informazione ai lavoratori: informativa (Allegato A), formazione.
6. Verifiche: [incontro periodico], comunicazione di [statistiche anonime / numero di
accessi
   dei custodi], riesame al termine del pilota.
7. Durata e modifiche: ogni modifica di strumenti, durate o finalità richiede un nuovo
accordo.

[Firme]
```

Passo 7 – Procedura dei custodi e designazioni (Allegato C)

Riferimento: Allegato C di `governance/policy-uso-ia.md`; istruzioni operative in `docs/custodi.md`.

☐ designazione di **almeno tre custodi** (soglia 2) **distinti dagli amministratori di sistema**, con sostituti; tipo di supporto e luogo di custodia delle quote `[ ]`
☐ designazione degli **amministratori di sistema** (provv. Garante 27/11/2008) e verifica annuale

☐ **postazione offline** dedicata `[ ]`
☐ **account di custodia** (Primary Owner) con password e secondo fattore divisi tra due custodi
☐ procedure: C.1 autorità giudiziaria; C.2 recupero dei progetti (approvazione del dirigente `[ ]`); C.3 rotazione forzata; C.4 verifica annuale e ridistribuzione delle quote; C.5 divieti
☐ **cerimonia di generazione** con verbale (`custodi.py verbale --tipo generazione`)
☐ prova di un recupero e di un'esportazione di prova con estrazione parziale e distruzione, con verbale

Campi minimi del **verbale dei custodi**: data e ora; operazione; estremi della richiesta (protocollo); custodi e testimoni presenti; commit dello strumento; impronte dei file in ingresso e in uscita; dati estratti (solo quelli richiesti); distruzione del resto; esito; firme; protocollazione.

Passo 8 – Procedura di cancellazione e distruzione dei backup (Allegato B)

Riferimento: Allegato B di `governance/policy-uso-ia.md`.

☐ **principio**: cancellazione crittografica (si cancellano le voci e, quando una chiave non ha più voci, la sua copia di custodia; senza chiave i dati nei backup non sono più decifrabili)
☐ cancellazioni **ordinarie** automatiche (durate del §5.4) e **su richiesta** (utente dal pannello, esercizio dei diritti tramite DPO)
☐ **registro delle cancellazioni** in sola aggiunta, esportato fuori dal database
☐ dopo ogni **ripristino** da backup: riapplicazione del registro **prima** di rimettere in servizio
☐ rotazioni dei backup (DB ≤ 35 giorni con copia offline; key store 14 giorni, su supporti separati), backup cifrati
☐ **verbale di distruzione** (copia offline, supporti dismessi, esportazioni): data, operatori, oggetto e impronta, metodo, esito della verifica, firme, protocollo
☐ **verifica annuale** a campione, insieme a quella sugli amministratori di sistema
☐ i dati sotto **blocco dell'autorità giudiziaria** non si cancellano fino a revoca

Passo 9 – Durate di conservazione

Approvare la tabella del §5.4 (regolamento art. 11, DPIA §2.5) e configurare gli stessi valori sul server.

Passo 10 – Adempimenti finali e avvio

☐ **registro dei trattamenti** aggiornato (art. 30 GDPR)
☐ **formazione** documentata di utenti e custodi (art. 4 AI Act)
☐ configurazione tecnica verificata (`docs/verifica-pilota.md`) e impostazioni di Claude Team (§3.6)
☐ procedura **data breach** aggiornata con gli scenari Pseudomania
☐ **AI Act**: classificazione degli usi (non ad alto rischio), trasparenza per testi pubblicati **[DA VERIFICARE]**
☐ **CAD** artt. 68-69: valutazione comparativa, pubblicazione del codice per il riuso
☐ regolamento adottato e pubblicato internamente; sintesi sul sito istituzionale (art. 14 L. 132/2025)

☐ licenze dei componenti rispettate (NOTICE del DFKI, attribuzioni di Rizzo-PII, sorgente AGPL)
☐ **riesame** al termine del pilota e comunque entro 12 mesi

E se l'organizzazione è un'impresa privata?

Il percorso è lo stesso, con alcune differenze da valutare con il consulente **[DA VERIFICARE]**: non si applicano le norme specifiche della PA (art. 14 L. 132/2025, CAD, qualificazione ACN, codici di comportamento dei dipendenti pubblici); la base giuridica sarà di regola diversa dall'interesse pubblico (per esempio contratto o legittimo interesse, con relativo bilanciamento); restano pienamente applicabili GDPR, DPIA, art. 4 L. 300/1970 e art. 4 AI Act.

5.4 Tabella delle durate con le fonti (Enterprise edition)

Fonti: DECISIONI.md (durate vincolanti), regolamento art. 11 e DPIA §2.5 (motivazioni). I link sono nell'Appendice.

Dato	Durata	Motivazione e fonti
Dizionario delle chat	30 giorni dall'ultimo uso; nessun recupero dopo cambio PC	Minimizzazione e limitazione della conservazione (art. 5, par. 1, lett. c ed e, GDPR)
Dizionario dei progetti	durata del progetto + 30 giorni dall'ultimo uso; conferma annuale dell'utente (senza conferma scade); recupero via custodi solo su richiesta motivata	Come sopra; la conferma evita dizionari dimenticati
Scope `pending:`	24 ore	Tecnica
Registro minimo (`audit_events`)	**90 giorni** in forma pseudonima, poi solo aggregati anonimi (giorno, ufficio, azione, conteggi)	Garante, documento di indirizzo 6/6/2024 (doc. web 10026277): oltre 21 giorni servono le garanzie dell'art. 4, c. 1, L. 300/1970; provv. Regione Lombardia (doc. web 10134221): ordine di limitare i log a 90 giorni e poi anonimizzarli. I 90 giorni sono **subordinati all'accordo sindacale o all'autorizzazione INL**
Tracce Langfuse	30 giorni nel pilota, poi 7	Minimizzazione; testi pseudonimizzati, servono solo a misurare il rilevamento (per analogia EDPB, Linee guida 3/2019 sui dispositivi video **[DA VERIFICARE: paragrafo]**)

Dato	Durata	Motivazione e fonti
Backup del DB applicativo	rotazione ≤ 35 giorni (7 giornalieri + 4 settimanali), una copia offline	Continuità di servizio; EDPB, azione coordinata 2025 sul diritto alla cancellazione (difficoltà di cancellare dai backup → durata breve e riapplicazione delle cancellazioni)
Key store e suoi backup	backup separati, rotazione 14 giorni	Separazione chiavi/dati; ACN, Linee guida banche dati (nov. 2024)
Copie di custodia (escrow)	stessa vita della chiave (rotazione 90 giorni), distrutte con la chiave	Cancellazione crittografica (NIST SP 800-88 Rev. 2, *cryptographic erase* come tecnica di *purge*)
Registri degli accessi di amministratori e custodi; registro delle cancellazioni	24 mesi, sola aggiunta, catena di hash	Garante, provv. 27/11/2008 sugli amministratori di sistema (log inalterabili, almeno 6 mesi); ACN, Linee guida banche dati (almeno 24 mesi)
Verbali dei custodi e richieste dell'autorità	protocollati, secondo il massimario dell'ente	Linee guida AgID sulla formazione, gestione e conservazione dei documenti informatici **[DA VERIFICARE: determinazione vigente]**
Blocco per autorità giudiziaria	sospende la cancellazione dei soli dati indicati, fino a revoca, registrato	Obblighi di legge
Conversazioni su claude.ai (Team)	a tempo indeterminato salvo cancellazione; conservazione personalizzata solo sul piano Enterprise	Condizioni del fornitore (Privacy Center di Anthropic) **[DA VERIFICARE: tempi di rimozione dal back-end]**
Feedback ad Anthropic	fino a 5 anni, usabili per l'addestramento → **disattivati**	Privacy Center di Anthropic

Personal edition (per il modello light): dizionario delle chat 30 giorni dall'ultimo uso; chat non ancora salvate 24 ore; progetti finché l'utente non li elimina; registro locale 90 giorni (valore predefinito del prodotto, non una durata fissata da norme); conversazioni su claude.ai secondo le condizioni del piano.

6. Risoluzione dei problemi

Regola generale: **se Pseudomania non funziona come previsto, non inviare dati personali** finché il problema non è risolto. Per l'Enterprise edition i problemi del server sono trattati in `docs/installazione-ente.md` §25.

6.1 Per tutti gli utenti

Sintomo / messaggio	Causa probabile	Che cosa fare
Nessuna barra di Pseudomania sopra la casella di claude.ai	estensione disattivata o rimossa, pagina non ancora caricata, sito cambiato	ricarica la pagina; controlla in `chrome://extensions` che Pseudomania sia attiva; se persiste, non inviare dati e aggiorna l'estensione / avvisa l'assistenza
«Pagina non riconosciuta da Pseudomania» / «Pseudomania non riconosce la struttura di questa pagina…»	claude.ai è stato aggiornato e i selettori non corrispondono più	non inviare dati personali; attendi l'aggiornamento dell'estensione; (Enterprise) contatta l'assistenza
«Non è stato possibile sostituire il testo nella casella di scrittura: l'invio è bloccato per sicurezza.»	la casella non ha accettato il testo pseudonimizzato	ricarica la pagina e riprova; se si ripete, segnalalo
Segnaposto in **rosso** nella risposta	Claude ha inventato o alterato un segnaposto	controlla quel punto; chiedi a Claude di usare solo i segnaposto presenti
Segnaposto in **grigio**, «… non sono ripristinabili»	dizionario cifrato su un altro computer o profilo	chat: nessun recupero; progetti Enterprise: §4.10
Segnaposto non ripristinati in una chat vecchia, senza avviso	dizionario scaduto (30 giorni dall'ultimo uso) o eliminato	comportamento previsto; recupera i dati dai tuoi documenti
«Invio bloccato» con riferimento all'art. 9 o 10 GDPR	filtro delle categorie particolari	riformula senza quei riferimenti; se è un errore usa **Segnala blocco errato** (§4.9)
«Il file «…» non è stato allegato: …»	formato non gestito (es. immagine) o file troppo grande	converti in DOCX/PDF/TXT senza immagini o riduci il file
PDF arrivato a Claude come `.txt`	Personal edition	comportamento previsto (§2.7)
File scaricato con i segnaposto e un avviso	formato non ripristinabile (es. PDF nella Personal) o errore del servizio	sostituisci a mano i valori o rigenera in DOCX/XLSX
Il contrassegno «dati protetti» apre nulla	Chrome ha rifiutato l'apertura del pannello laterale	(Personal) clic destro sul pulsante → **Apri pannello di ispezione**; (Enterprise) clic sul pulsante → **Apri pannello di ispezione**

Sintomo / messaggio	Causa probabile	Che cosa fare
Contrassegni spariti sui messaggi vecchi	i dati di ispezione restano solo nella sessione	comportamento previsto dopo la chiusura del browser
Microfono/dettatura non funzionano su claude.ai	dettatura disattivata da Pseudomania	comportamento previsto
Avviso arancione «non è stato possibile associare i segnaposto a questa conversazione (conflitto sul server)»	conflitto nel passaggio dal dizionario provvisorio a quello della chat	la protezione resta attiva; continua pure; segnala se si ripete (Enterprise)

6.2 Personal edition

Sintomo / messaggio	Causa probabile	Che cosa fare
Badge **!** rosso, «Rizzo-PII non raggiungibile: avvia l'app desktop di Rizzo-PII»	app Rizzo-PII chiusa o bloccata	avvia l'app; apri `http://127.0.0.1:5005/health` in Chrome
«Rizzo-PII si sta avviando (caricamento del modello)» a lungo	primo download del modello o memoria insufficiente	attendi; chiudi altri programmi; controlla lo spazio su disco
Porta 5005 occupata	un altro programma usa la porta	chiudi il programma oppure scegli un'altra porta in Rizzo-PII e indicala in **Impostazioni** (solo `127.0.0.1`) **[DA VERIFICARE con l'app reale]**
«Rizzo-PII risponde ma rifiuta le chiamate dell'estensione (CORS)»	il servizio locale non accetta l'estensione	**non usare la Personal edition con dati di clienti**; scarica la versione modificata di Rizzo-PII quando sarà fornita sul sito (§2.2)
Finestra «Rizzo-PII non risponde» con **Invia senza protezione**	Rizzo-PII spento durante l'uso	scegli **Annulla**, riavvia Rizzo-PII, riprova
Badge **OFF** rosso, barra rossa	protezione disattivata **in questa conversazione**	clic sul pulsante o Alt+Maiusc+P (§2.6)
Badge **?** arancione, banner «Vuoi attivare Pseudomania per questa conversazione?»	conversazione nuova o ripresa dopo uno spegnimento	scegli **Attiva** o **Continua senza protezione**; nel frattempo i messaggi sono pseudonimizzati
Alt+Maiusc+P non fa nulla	scorciatoia occupata da un altro programma o modificata	`chrome://extensions/shortcuts`
La protezione si è riaccesa (o spenta) da sola cambiando chat	lo stato è salvato per conversazione	comportamento previsto: controlla il badge a ogni chat
«Sono ammessi solo indirizzi locali» nelle impostazioni	indirizzo non locale	usa `http://127.0.0.1:<porta>` o `http://localhost:<porta>`

Sintomo / messaggio	Causa probabile	Che cosa fare
Dizionario perso dopo un aggiornamento	l'estensione è stata rimossa e reinstallata	aggiorna sempre nella stessa cartella con **Aggiorna** (§2.9); i dati persi non si recuperano
L'estensione dal pacchetto si disattiva all'avvio di Chrome	alcune versioni di Chrome avvisano per le estensioni in modalità sviluppatore **[DA VERIFICARE]**	riattivala in `chrome://extensions`; usa la versione del Web Store quando disponibile

6.3 Enterprise edition (utente e help desk)

Sintomo / messaggio	Causa probabile	Che cosa fare
«Accesso richiesto: effettua il login a Pseudomania dal pulsante dell'estensione»	token scaduto o browser riavviato	clic sul pulsante di Pseudomania → **Accedi**
«Non è stato possibile autenticarsi presso il server Pseudomania…»	IdP non raggiungibile, client OIDC o audience errati	utente: riprova **Accedi**; IT: verificare redirect URI, `OIDC_AUDIENCE`, mapper *Audience* (Keycloak), CORS dell'IdP (`docs/configurazione.md` §B.1)
«Il server Pseudomania non è raggiungibile: … l'invio è bloccato»	server spento, rete, certificato non attendibile	utente: riprova più tardi; IT: `curl https://pseudogate.ente.local/v1/health`, certificato della CA interna distribuito ai PC
«Il servizio di riconoscimento dei dati personali non è disponibile»	`rizzo-pii` in avvio o guasto (`detector: down`)	IT: `docker compose ps`, log di `rizzo-pii`
«Servizio chiavi del server non disponibile»	OpenBao sigillato (`keys: sealed`) o irraggiungibile	IT: sblocco di OpenBao con i custodi (`docs/installazione-ente.md` §22)
Pseudomania in Personal edition su un PC dell'ente	policy di Chrome non applicata a quel profilo	IT: `chrome://policy` → **Ricarica criteri**; applicare la policy a tutti i profili
L'estensione non compare o non è «Installata dall'amministratore»	`ExtensionInstallForcelist`/`update.xml` errati, ID diverso, PC non gestito	IT: verificare ID, URL di `update.xml`, versione coerente tra manifest e `update.xml`
«Prepara il recupero» non porta a nulla	chiave non ancora caricata dai custodi o scaduta (7 giorni)	help desk: verificare lo stato del ticket; utente: **Verifica chiavi recuperate**
«La conferma annuale scade a breve»	scadenza del progetto	utente: confermare dal pannello (§4.11)
Accesso a claude.ai rifiutato da un PC o dalla rete	accesso condizionato dell'SSO	comportamento previsto fuori dai dispositivi gestiti

7. Glossario

Allowlist (elenco di eccezioni) – Termini pubblici (enti, istituzioni, uffici) che non vengono mai sostituiti da segnaposto.

Anteprima – Finestra che mostra, prima dell'invio, il testo originale e quello che partirà verso Claude. Si apre con **Ctrl+Maiusc+Invio**.

Categorie particolari di dati – Dati che rivelano origine razziale o etnica, opinioni politiche, convinzioni religiose o filosofiche, appartenenza sindacale, dati genetici, biometrici, relativi alla salute, alla vita o all'orientamento sessuale (art. 9 GDPR); a questi si aggiungono i dati relativi a condanne penali e reati (art. 10 GDPR). Pseudomania blocca gli invii in cui li rileva.

Chiave di custodia – Coppia di chiavi RSA dell'organizzazione (Enterprise). La chiave pubblica è sul server e serve a cifrare le copie di custodia; la chiave privata non è mai sul server ed è divisa in quote tra i custodi.

Chiave utente – Chiave AES-256 generata automaticamente dal browser di ciascun utente, **non estraibile**, con cui l'estensione cifra il dizionario. Ruota ogni 90 giorni (Enterprise).

Claude Team – Piano commerciale di Anthropic per claude.ai destinato alle organizzazioni.

Copia di custodia (escrow) – Copia della chiave utente cifrata con la chiave pubblica di custodia, conservata nel key store; si apre solo con due custodi.

CORS – Meccanismo di sicurezza dei browser che decide se una pagina o un'estensione può leggere le risposte di un altro indirizzo. Rilevante per il dialogo tra estensione e Rizzo-PII o il server.

Custode – Persona designata che detiene una quota della chiave privata di custodia (e, per due di loro, password o secondo fattore dell'account Primary Owner). Opera solo con un altro custode e con verbale.

Dizionario – Corrispondenza tra segnaposto e valori reali, per conversazione o per progetto. Sempre cifrato.

DPA (Data Processing Addendum) – Accordo sul trattamento dei dati tra cliente e fornitore (art. 28 GDPR).

DPIA – Valutazione d'impatto sulla protezione dei dati (art. 35 GDPR).

DPO / RPD – Responsabile della protezione dei dati (artt. 37-39 GDPR).

Fail-closed – Comportamento per cui, se il servizio di riconoscimento non risponde, l'invio viene bloccato invece di partire senza protezione (Enterprise).

HMAC – Impronta calcolata con una chiave segreta. Serve a dare lo stesso segnaposto allo stesso valore senza conservarlo in chiaro, e a rendere pseudonima l'identità degli utenti nel registro.

IdP (identity provider) – Sistema che autentica gli utenti dell'organizzazione (es. Keycloak, Microsoft Entra ID), usato per l'SSO e per l'accesso dell'estensione al server.

IndexedDB – Archivio locale del browser in cui l'estensione conserva dizionario e registro (Personal) e le chiavi non estraibili.

Key store – Database separato in cui il server conserva le copie di custodia, con backup propri a 14 giorni.

Langfuse – Piattaforma di osservabilità in cui l'Enterprise edition registra, per pochi giorni, i testi **già pseudonimizzati**, per misurare la qualità del riconoscimento.

OpenBao – Servizio che custodisce sul server la sola chiave HMAC; si sblocca con le quote dei custodi.

Pannello di ispezione – Pannello laterale di Pseudomania che mostra originale e testo inviato, dati sostituiti, segnalazioni, cancellazione dei dati, conferma e recupero dei progetti.

Personal edition / Enterprise edition – Le due edizioni di Pseudomania (capitolo 1, §1.3).

Primary Owner – Ruolo più alto di un'organizzazione Claude Team; è l'unico che può esportare i dati dell'organizzazione. Nell'Enterprise edition è assegnato a un account di servizio a doppia custodia.

Progetto – Funzione di claude.ai che raccoglie chat, istruzioni e file; in Pseudomania ha un unico dizionario per tutte le sue chat.

Pseudonimizzazione – Trattamento per cui i dati non possono più essere attribuiti a una persona senza informazioni aggiuntive conservate separatamente (art. 4, n. 5, GDPR). I dati pseudonimizzati **restano dati personali**.

Quasi-identificatori – Informazioni che, senza nome, permettono comunque di riconoscere una persona (ruolo unico, data e luogo di un fatto, numero di protocollo…). Pseudomania non li riconosce.

Quota (Shamir) – Parte di un segreto diviso con lo schema di Shamir: servono almeno «soglia» quote (es. 2 di 3) per ricomporlo; una sola quota non rivela nulla.

Registro minimo – Registro del server (Enterprise) con data e ora, pseudonimo dell'utente, ufficio, azioni, conteggi, blocchi e impronta SHA-256 del testo pseudonimizzato; **nessun testo**.

Rizzo-PII – Modello e servizio open source per il riconoscimento dei dati personali in italiano; nella Personal edition gira come app desktop sul PC, nell'Enterprise edition sul server.

Scope – Ambito di un dizionario: una conversazione, un progetto o una chat nuova non ancora salvata (`pending:`).

Segnaposto (tag) – Stringa `[TIPO_N]` che sostituisce un dato personale, es. `[FULLNAME_1]`, `[CF_2]`, `[IBAN_1]`.

SHA-256 (impronta) – Funzione che produce un’impronta di un testo; permette di verificare l’autenticità di un messaggio esportato senza conservarne il contenuto.

SSO – Accesso unico con le credenziali dell’organizzazione.

Verbale – Documento redatto a ogni operazione dei custodi o di distruzione, poi protocollato.

Appendice – Riferimenti e link

Sono riportati solo i collegamenti già citati in `governance/` (consultati dagli autori dei documenti di governance il 30-31/10/2026) o verificati durante la stesura del manuale (31/10/2026). I documenti segnati **[DA VERIFICARE]** nelle fonti originali restano tali.

A.1 Pseudomania

- Sito ufficiale: https://pseudomania.statocritico.it
- Licenza: GNU AGPL-3.0-or-later, file `LICENSE` del repository (sezioni 15-17: assenza di garanzia e limitazione di responsabilità); attribuzioni in `THIRD_PARTY_NOTICES.md`
- Documenti del repository citati nel manuale: `DECISIONI.md`, `SPEC.md`, `extension/README.md`, `docs/` (installazione, configurazione, custodi, verifica del pilota, problemi rilevati), `governance/` (regolamento con allegati A-B-C, modello light, DPIA, checklist, verifiche di fase 0), `tools/custodi/`

A.2 Componenti di terzi

- Rizzo-PII, rilasci: https://github.com/Rizzo-AI-Academy/rizzo-pii/releases (verificato il 31/10/2026: rilascio 2.0.0 «Latest» e 1.0.0 con pacchetti Windows, Linux e macOS arm64)
- Rizzo-PII, wiki: https://github.com/Rizzo-AI-Academy/rizzo-pii/wiki
- Rizzo-PII, licenze di terze parti: https://github.com/Rizzo-AI-Academy/rizzo-pii/blob/main/THIRD_PARTY_LICENSES.md
- Modello Rizzo-PII su Hugging Face: https://huggingface.co/rizzoaiacademy/rizzo-pii-0.3B
- DFKI, Privacy Guardrail (progetto da cui deriva in parte l'estensione): https://github.com/dfki-dsa/pii-guardrail-browser-extension

A.3 Anthropic (Claude)

- Commercial Terms: https://www.anthropic.com/legal/commercial-terms
- Data Processing Addendum: https://www.anthropic.com/legal/data-processing-addendum
- Usage Policy: https://www.anthropic.com/aup
- Sub-responsabili: https://www.anthropic.com/subprocessors
- Privacy Center, GDPR: https://privacy.claude.com/en/articles/10458704-how-do-you-handle-gdpr-and-similar-data-protection-laws
- Privacy Center, conservazione dei dati dell'organizzazione: https://privacy.claude.com/en/articles/10440198-how-long-do-you-store-my-organization-s-data
- Privacy Center, cancellazione dei dati Claude for Work: https://privacy.claude.com/en/articles/9796617-can-you-delete-data-that-i-sent-via-claude-for-work-team-enterprise-plans
- Privacy Center, uso dei dati per l'addestramento: https://privacy.claude.com/en/articles/7996868-is-our-data-used-for-model-training

- Help Center, esportazione dei dati dell'organizzazione (verificato il 31/10/2026: solo Primary Owner dei piani Team ed Enterprise, *Data and privacy › Export Data*): https://support.claude.com/en/articles/13346720-export-your-organization-s-data

A.4 Norme e atti

- L. 23 settembre 2025, n. 132 (Normattiva): https://www.normattiva.it/eli/id/2025/09/25/25G00143/CONSOLIDATED
- Agenda Digitale, L. 132/2025 e uso dell'IA nella PA: https://www.agendadigitale.eu/cittadinanza-digitale/legge-132-2025-e-uso-dellai-nella-nella-pubblica-amministrazione-la-guida/
- AI Act, art. 4 (alfabetizzazione): https://artificialintelligenceact.eu/article/4b/
- Art. 4 L. 300/1970 (testo, Assolombarda): https://new.assolombarda.it/servizi/diritto-di-impresa/documenti/art-4-legge-300-del-1970
- Art. 68 CAD: https://miolegale.it/codici/codice-amministrazione-digitale/art-68/
- AgID, Intelligenza artificiale: https://www.agid.gov.it/it/ambiti-intervento/intelligenza-artificiale
- Regolamento unico ACN sul cloud per la PA (sintesi): https://quifinanza.it/innovazione/regolamento-unico-infrastrutture-servizi-cloud/832868/

A.5 Garante, EDPB, ACN, NIST

- Garante, provv. n. 467/2018 (elenco dei trattamenti soggetti a DPIA): https://garanteprivacy.it/garante/doc.jsp?ID=9058979
- Garante, documento di indirizzo 6/6/2024 sui metadati della posta elettronica (doc. web 10026277): https://dirittobancario.it/wp-content/uploads/2024/06/Provvedimento-Garante-Privacy-6-giugno-2024.pdf
- Garante, provv. Regione Lombardia (doc. web 10134221), sintesi: https://www.cybersecurity360.it/news/sanzione-privacy-a-regione-lombardia-50mila-euro-per-controllo-illecito-di-email-e-internet/ e https://privacymatters.dlapiper.com/2025/06/italy-the-garante-issues-first-gdpr-fine-over-employees-email-metadata-privacy-breach/
- Garante, provv. 27/11/2008 sugli amministratori di sistema (sintesi): https://www.filodiritto.com/le-nuove-prescrizioni-privacy-i-titolari-del-trattamento-relativamente-alle-attribuzioni-delle-funzioni-di-amministratore-di-sistema
- EDPB, Linee guida 01/2025 sulla pseudonimizzazione: https://edpb.europa.eu/news/news/2025/edpb-adopts-pseudonymisation-guidelines-and-paves-way-improve-cooperation_en
- EDPB, azione coordinata 2025 sul diritto alla cancellazione: https://www.edpb.europa.eu/news/edpb-identifies-challenges-hindering-the-full-implementation-of-the-right-to-erasure_en
- EDPB, Linee guida 3/2019 sui dispositivi video **[DA VERIFICARE]**: https://www.edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_201903_video_devices_en.pdf
- CGUE, C-413/23 P, *EDPS c. SRB* (sintesi): https://www.cliffordchance.com/insights/resources/blogs/talking-tech/en/articles/2025/09/pseudonymized-data-after-edps-v-srb.html

- ACN, Linee guida per il rafforzamento della protezione delle banche dati (nov. 2024) **[DA VERIFICARE: copia sul sito ufficiale ACN]**: https://cybersecitalia.it/wp-content/uploads/2024/11/Linee-guida-banche-dati.pdf
- NIST SP 800-88 Rev. 2: https://csrc.nist.gov/pubs/sp/800/88/r2/final

Avvertenze finali

Si richiamano le avvertenze del **capitolo 0**, che fanno parte integrante di questo manuale:

1. Pseudomania è uno **strumento di mitigazione del rischio**, **non una garanzia di anonimizzazione**: i dati pseudonimizzati **restano dati personali** e il riconoscimento **può non individuare** alcuni dati e il contesto che identifica le persone.
2. **Tutta la responsabilità giuridica** — rispetto del GDPR e del Codice privacy, DPIA, policy e regolamenti, diritto del lavoro (art. 4 L. 300/1970), contratti con i fornitori di IA, esiti dell'uso dell'IA — resta **interamente** in capo a chi adotta e usa il sistema.
3. Il software è fornito **senza alcuna garanzia** e **gli autori non sono responsabili** di alcun danno, nei termini delle **sezioni 15 e 16 della licenza AGPL-3.0** (testo vincolante nel file `LICENSE`).
4. I modelli di policy, informativa, accordo e DPIA sono **bozze da adattare**, non consulenza legale; i punti marcati **[DA VERIFICARE]** vanno controllati prima dell'uso.

Sito: https://pseudomania.statocritico.it